LAPORAN FINAL VULNERABILITY ASSESSMENT & PENETRATION TESTING

RUANGSURAT — APLIKASI PENGAJUAN DOKUMEN INTERNAL

Security Assessment pada Lingkungan Staging / Praproduksi

PTES • OWASP WSTG v4.2 • OWASP Top 10:2025 • CVSS v3.1

Identitas dokumen	Keterangan
Disusun oleh	Kevin McLoud
Objek pengujian	Aplikasi RuangSurat; lingkungan staging sebelum production
Periode assessment	22 Oktober 2026, zona Asia/Jakarta (WIB; UTC+07:00)
Tanggal penyusunan final	22 Oktober 2026
Versi / status	1.1 / Final — Revisi penyajian
Target utama	http://127.0.0.1:8080 — baseline staging (vulnerable)
Target pembanding	http://127.0.0.1:8081 — kandidat perbaikan (fixed)
Nomor dokumen	RS-VAPT-2026-10-KM-01

CONFIDENTIAL • INTERNAL USE ONLY

Dokumen ini menyajikan hasil Vulnerability Assessment and Penetration Testing (VAPT) terhadap aplikasi RuangSurat pada lingkungan staging sebelum rilis ke production. Assessment mencakup pengujian manual, pemeriksaan implementasi, dan validasi perbaikan. Laporan ditujukan kepada manajemen, pemilik aplikasi, tim pengembang, dan tim infrastruktur sebagai dasar prioritas remediasi serta evaluasi kesiapan rilis.

LEMBAR PENGESAHAN DAN KENDALI DOKUMEN

Identitas dan tanggung jawab

Elemen	Keterangan final
Nama kegiatan	VAPT aplikasi RuangSurat sebelum rilis production
Penguji keamanan aplikasi	Kevin McLoud
Pemilik aplikasi / penerima laporan	Pengelola Aplikasi RuangSurat / Manajemen dan Tim Teknologi Informasi
Peninjauan dan persetujuan rilis	Mengikuti proses change management pemilik aplikasi; persetujuan tidak dicatat dalam naskah ini
Persetujuan administratif	Tanda tangan dan tanggal pengesahan tidak disertakan dalam salinan digital ini
Lingkungan	Staging berbasis Docker; production dan host infrastruktur berada di luar objek penilaian
Bahasa / versi	Bahasa Indonesia / 1.1 Final — Revisi penyajian

Assessment dilakukan pada aplikasi RuangSurat untuk menilai perlindungan dokumen, kontrol akses antarstaf, keamanan konten yang ditinjau administrator, serta pengelolaan lampiran. Alya Pratama, Bima Saputra, dan Nadia Putri merupakan identitas akun pengujian dengan hak staf dan administrator. Pencatatan pengesahan dan persetujuan rilis mengikuti proses internal pemilik aplikasi.

Riwayat versi

Versi	Tanggal	Penyusun	Perubahan	Status
1.1	22 Oktober 2026	Kevin McLoud	Penyederhanaan penyajian: severity memakai CVSS v3.1; dampak dan prioritas dijelaskan secara naratif; bukti dan hasil retest dipertahankan	Final

Distribusi, retensi, dan integritas

Distribusi laporan dibatasi kepada manajemen, pemilik aplikasi, tim teknologi informasi, pengembang, dan pihak yang menangani remediasi. Dokumen dan evidence memuat informasi teknis internal sehingga penyimpanan, akses, retensi, serta pemusnahannya mengikuti kebijakan pengelolaan informasi perusahaan. Target penyelesaian dan penerimaan risiko perlu ditetapkan oleh pemilik aplikasi sebelum persetujuan rilis.

Dokumen dikelola sebagai versi 1.1 dengan identitas, riwayat perubahan, serta klasifikasi distribusi yang konsisten. Screenshot manual ditanam sebagai gambar asli tanpa pemotongan dan tanpa mengubah isi. Kredensial, cookie, dan nilai token aktif tidak dituliskan pada narasi maupun contoh request.

DAFTAR ISI

LEMBAR PENGESAHAN DAN KENDALI DOKUMEN..... 2
RINGKASAN EKSEKUTIF..... 4
BAB 1 INFORMASI UMUM..... 5
BAB 2 METODOLOGI..... 9
BAB 3 BATASAN DAN KENDALA..... 13
BAB 4 RINGKASAN TEMUAN..... 15
BAB 5 TECHNICAL DETAILS..... 17
BAB 6 PENUTUP DAN RETEST..... 39
REFERENSI SINGKAT..... 43

Daftar isi merupakan field dokumen Word. Struktur judul dapat digunakan melalui Navigation Pane; nomor halaman mengikuti hasil pembaruan field pada aplikasi pengolah dokumen.

RINGKASAN EKSEKUTIF

Pelaksanaan VAPT terhadap aplikasi RuangSurat pada lingkungan staging menemukan tiga kelemahan yang dapat direproduksi pada baseline pengujian: pembacaan dokumen lintas pemilik, eksekusi JavaScript melalui tautan yang disimpan staf dan dibuka administrator, serta eksekusi PHP dari lampiran. Assessment dilaksanakan oleh Kevin McLoud dan didukung 14 screenshot pengujian tanggal 22 Oktober 2026. Ketiga temuan memengaruhi batas kepercayaan antara pengguna dan dokumen, input staf dan browser administrator, serta berkas unggahan dan runtime server.

Temuan paling tinggi adalah VULN-03, karena lampiran PHP diproses sebagai kode oleh server. Bukti memperlihatkan output `EXECUTED_5`, bukan source PHP yang diunduh. Temuan VULN-01 memperlihatkan akun Bima Saputra membaca surat tugas milik Alya Pratama pada `/documents/12`. Temuan VULN-02 memperlihatkan dialog `PENTEST_02` dalam sesi Nadia Putri setelah tautan referensi pada pengajuan staf dibuka. Ketiganya terkonfirmasi pada staging. Dampak yang sudah terbukti dan potensi terhadap kerahasiaan, integritas, serta ketersediaan dijelaskan terpisah pada setiap temuan.

ID	Temuan utama	Severity teknis / CVSS v3.1	Dampak yang dibuktikan
VULN-01	IDOR pada pembacaan detail dokumen	Medium / 4.3	Bima membaca isi dan identitas pemilik dokumen Alya
VULN-02	Stored XSS melalui tautan referensi	Medium / 5.4	JavaScript tersimpan berjalan ketika tautan dibuka admin
VULN-03	Upload PHP menghasilkan eksekusi kode aplikasi	High / 8.8	Interpreter server menjalankan ekspresi PHP dari lampiran

Distribusi severity teknis adalah **0 Critical, 1 High, 2 Medium, dan 0 Low**. Proporsinya adalah 33,33% High dan 66,67% Medium. Terdapat dua observasi pendukung, yaitu framing dan CORS untuk informasi publik, yang tidak dihitung sebagai temuan keamanan tambahan karena skenario yang diuji tidak membuktikan pelanggaran kebijakan atau dampak sensitif yang terpisah.

Urutan penanganan yang disarankan adalah VULN-03, VULN-01, lalu VULN-02. Penanganan upload membutuhkan pemisahan lokasi penyimpanan dari interpreter dan validasi file; IDOR membutuhkan otorisasi per objek pada server; Stored XSS membutuhkan allowlist URL, encoding sesuai konteks, dan penonaktifan tautan berbahaya lama. Rekomendasi mengacu pada akar masalah yang terlihat pada implementasi, bukan sekadar perubahan tampilan menu.

Validasi terhadap kandidat perbaikan (fixed) menunjukkan request eksploitasi ditolak dan fungsi sah tetap berjalan. Bukti retest dicatat melalui tes API dan browser yang terpisah dari rangkaian manual. **Baseline staging berstatus Open untuk ketiga temuan; kandidat perbaikan memenuhi skenario retest yang dijalankan.** Baseline yang masih rentan direkomendasikan berstatus HOLD untuk rilis ke production. Promosi kandidat perbaikan memerlukan penerapan konfigurasi yang setara, penyelesaian pemeriksaan kesiapan rilis, dan persetujuan pemilik aplikasi.

Keputusan kesiapan rilis

Rekomendasi terhadap baseline staging: HOLD / TIDAK DIREKOMENDASIKAN UNTUK RILIS. Tiga temuan terkonfirmasi masih berstatus Open pada kondisi baseline, termasuk kemampuan eksekusi PHP dari akun staf. Kandidat perbaikan menunjukkan hasil retest yang memenuhi skenario terkait, tetapi promosi ke production memerlukan verifikasi build, konfigurasi deployment, pembersihan artefak pengujian, dan persetujuan pemilik aplikasi. Assessment ini tidak melakukan pengujian pada production.

BAB 1 INFORMASI UMUM

1.1. Latar belakang

RuangSurat merupakan aplikasi administrasi internal perusahaan untuk membuat, mengirim, meninjau, serta memutuskan pengajuan dokumen. Staf mengisi judul, kategori, dan keterangan, kemudian melengkapi lampiran serta tautan referensi sebelum pengajuan dikirim kepada administrator. Administrator meninjau pengajuan berstatus Menunggu review dan memberikan persetujuan atau penolakan. Assessment dilakukan pada staging menggunakan akun dan dokumen uji terkontrol sebelum aplikasi dipromosikan ke production.

Alur tersebut memiliki tiga batas keamanan yang relevan. Pertama, staf dengan hak yang setara tetap mempunyai kepemilikan dokumen berbeda. Kedua, data yang dibuat staf dapat ditampilkan kepada administrator yang mempunyai fungsi lebih luas. Ketiga, berkas yang berasal dari pengguna harus diperlakukan sebagai data, sementara server mempunyai kemampuan menjalankan kode PHP. Assessment memeriksa apakah aplikasi menjaga setiap batas tersebut secara konsisten.

Assessment membedakan baseline staging (vulnerable), yang merepresentasikan kondisi sebelum mitigasi, dan kandidat perbaikan (fixed), yang dipakai untuk memverifikasi efektivitas kontrol. Permintaan yang setara dibandingkan pada kedua versi dengan sesi serta data masing-masing. Status Fixed pada kandidat perbaikan tidak otomatis menutup temuan pada baseline atau menjadi persetujuan rilis production; hasil harus ditautkan ke build dan konfigurasi yang diverifikasi.

1.2. Tujuan pengujian

- Menentukan apakah pengguna staf dapat membaca dokumen di luar kepemilikannya dengan memanipulasi identifier.
- Menentukan apakah tautan yang tersimpan dapat menjalankan JavaScript dalam browser pengguna lain, khususnya administrator.
- Menentukan apakah unggahan PHP diterima dan diproses interpreter melalui direktori publik.
- Menjelaskan prasyarat, bukti, akar masalah, dampak terkonfirmasi, dan batas pembuktian setiap temuan.
- Menilai severity teknis secara konsisten serta menyusun rekomendasi yang dapat diverifikasi melalui pengujian ulang.
- Membuktikan bahwa kontrol pembanding menolak skenario bermasalah dan mempertahankan fungsi normal aplikasi.

1.3. Identitas, pendekatan, dan periode

Elemen	Keterangan
Penguji / penyusun	Kevin McLoud
Pendekatan	Grey-box: akun uji, kebijakan akses, source, dan konfigurasi staging tersedia
Bukti manual utama	paket evidence VULN-01, VULN-02, dan VULN-03
Tanggal kegiatan manual	22 Oktober 2026; tanggal tersebut tampil pada pengajuan yang direkam
Waktu pembuatan objek	RS-012: 04:08:35 WIB; RS-015: 04:21:00 WIB; RS-019: 04:50:48 WIB, berdasarkan database
Validasi tambahan	Tes integrasi API dan Chromium/Playwright dicatat sebagai run terpisah pada 22 Oktober 2026
Identifikasi build	`ruangsurat-1.1`; tag image `:1.1`; konfigurasi profil pada compose.yaml

Waktu pembuatan dokumen tidak sama dengan waktu pengambilan screenshot. Screenshot tidak diperlakukan sebagai rekaman timestamp forensik. Periode manual dinyatakan pada tingkat tanggal, sedangkan waktu persis yang dicantumkan di atas diberi sumber database. Waktu awal/akhir validasi tambahan tersimpan pada log run, sehingga kedua kelompok bukti tidak digabung menjadi satu transaksi.

1.4. Target dan ruang lingkup

Staging adalah lingkungan praproduksi untuk menilai kandidat aplikasi sebelum promosi. Istilah teknis `vulnerable` menunjuk baseline sebelum mitigasi, sedangkan `fixed` menunjuk kandidat perbaikan yang diuji. Penamaan tersebut mengikuti mode implementasi yang diperiksa; tidak menyatakan bahwa production mempunyai konfigurasi yang sama. Alamat loopback merupakan jalur akses staging yang benar-benar digunakan selama assessment.

Target	Fungsi	Status cakupan
http://127.0.0.1:8080	Profil vulnerable	Target utama screenshot manual dan reproduksi otomatis
http://127.0.0.1:8081	Profil fixed	Pembanding remediasi pada tes API/browser
http://127.0.0.1:8090	Origin PoC lokal	Pembanding browser untuk CORS publik dan framing
Aplikasi web dan API	Login, dokumen, tautan, lampiran, keputusan, logout	Skenario yang dijelaskan pada BAB 5 dan BAB 6
Windows/WSL, host Docker, internet, dan layanan lain	Infrastruktur di luar aplikasi staging	Di luar scope penilaian

Penggunaan `127.0.0.1` menunjukkan lokasi akses pada host pengujian. CVSS tetap menilai permintaan HTTP sebagai Attack Vector Network karena eksploitasi berlangsung melalui protokol jaringan terhadap layanan aplikasi; AV Local pada CVSS bukan sinonim aplikasi yang kebetulan diakses melalui localhost. Pembatasan loopback dicatat sebagai konteks eksposur operasional, bukan alasan mengubah cara kerja kelemahan.

1.5. Akun dan kebijakan akses

Aktor	Akun pengujian	Kebijakan yang diharapkan
Staf A / Alya Pratama	staf.a@example.test	Membaca dokumen sendiri; membuat dan mengubah draft sendiri; mengirim pengajuan
Staf B / Bima Saputra	staf.b@example.test	Hak staf yang sama; tidak boleh membaca dokumen Alya
Administrator / Nadia Putri	admin@example.test	Membaca pengajuan semua staf; memutuskan pengajuan submitted; mengakses direktori pengguna
Pengunjung anonim	Tidak memiliki sesi login	Tidak memperoleh isi dokumen atau akses API privat

Password tidak dicantumkan dalam laporan. Nama akun pengujian diperlukan untuk membedakan pembuat objek, pelaku uji akses, dan pihak yang membuka payload. Keberhasilan login hanya membuktikan autentikasi; akses terhadap dokumen tertentu tetap memerlukan otorisasi yang sesuai. Pada VULN-01, akun penyerang pada screenshot adalah **Bima**, sedangkan pemilik dokumen yang dibaca adalah **Alya**.

1.6. Aset dan konsekuensi proses bisnis

Aset	Kebutuhan perlindungan	Konsekuensi jika batas kepercayaan gagal
Isi dan metadata pengajuan	Kerahasiaan berdasarkan kepemilikan	Staf membaca tujuan, isi, dan identitas pemilik dokumen orang lain
Konteks browser administrator	Integritas tampilan dan tindakan	Input staf menjadi script aktif ketika admin membuka tautan
Runtime aplikasi dan storage	Pemisahan data dari kode	Berkas lampiran dijalankan dengan kemampuan proses aplikasi
Sesi dan token CSRF	Konsistensi autentikasi dan perubahan state	Akses atau perubahan tanpa prasyarat sesi yang benar
Integritas evidence	Keterlacakan dan kesesuaian bukti	Kesimpulan menjadi tidak dapat diaudit jika bukti berbeda run dicampur

Matriks akses staf dan administrator digunakan sebagai expected behavior. Seluruh objek yang dibuat untuk pengujian diberi identitas yang dapat ditelusuri. Nama badan usaha yang muncul di dalam judul dokumen merupakan konten objek uji dan tidak dipakai untuk menetapkan identitas organisasi pemilik aplikasi.

BAB 2 METODOLOGI

2.1. Kerangka pelaksanaan

PTES digunakan sebagai kerangka kegiatan, sedangkan OWASP WSTG v4.2 digunakan untuk menamai skenario pengujian web. OWASP Top 10:2025 dan CWE membantu mengelompokkan akar masalah. CVSS v3.1 digunakan untuk severity teknis agar konsisten dengan template dan metodologi assessment. Penyebutan kerangka tidak berarti semua test case atau semua layanan telah dinilai. Laporan berfokus pada aktivitas yang memiliki bukti dan membedakan pengujian dari analisis desain.

Tahap PTES	Penerapan aktual	Keluaran dan batas
Pre-engagement	Identifikasi target lokal, akun pengujian, kebijakan pemilik, dan batas tindakan	Scope, Rules of Engagement, dan batas pengujian staging
Intelligence Gathering	Navigasi fitur, pengamatan URL, serta pembacaan konfigurasi/source	Endpoint dokumen, tautan, upload; tidak ada raw output Nmap
Threat Modeling	Analisis tiga batas kepercayaan dan aset	Hipotesis akses lintas pemilik, script lintas pengguna, serta file menjadi kode
Vulnerability Analysis	Pemeriksaan parameter, validasi, dan jalur penyimpanan	Kandidat temuan dipastikan dengan screenshot dan kontrol pembanding
Exploitation	Perubahan ID, tautan JavaScript benign, dan marker PHP	Bukti akses isi, dialog browser, serta output interpreter
Post-exploitation	Penilaian batas kemampuan yang diperoleh	Tidak dilanjutkan ke shell, pencurian data, atau eskalasi host
Reporting	Pengisian salinan template dan penautan evidence	Laporan final, bukti pengujian, rekomendasi, dan hasil retest

2.2. Uraian tujuh tahap PTES

2.2.1. Pre-engagement

Target assessment ditetapkan sebagai aplikasi RuangSurat pada staging, dengan tiga akun uji dan alamat HTTP yang tercantum dalam scope. Staf dibatasi pada dokumen sendiri, sedangkan administrator meninjau pengajuan lintas staf. Aktivitas mencakup pembuatan dokumen uji, perubahan identifier, penambahan tautan, dan unggahan marker benign. Akses ke production, penghapusan massal, gangguan layanan, serta eskalasi ke host berada di luar ruang lingkup.

2.2.2. Intelligence Gathering

Pengamatan antarmuka mengidentifikasi alur pembuatan draft, lampiran, tautan, pengiriman, dan review. Address bar memperlihatkan `/documents/12`, `/documents/15`, serta URL `/uploads/...php`. Pengetahuan tentang PHP, Apache, SQLite, sesi, dan endpoint POST diperoleh dari source/config serta tes, bukan diklaim sebagai hasil fingerprinting otomatis pada screenshot. Tidak ada hasil port scan, audit TLS, atau identifikasi WAF yang dijadikan keluaran kegiatan ini.

2.2.3. Threat Modeling

Untuk aset dokumen, ancaman utama adalah staf mengganti identifier untuk melewati kepemilikan. Untuk browser admin, ancaman muncul ketika input staf disimpan dan ditampilkan sebagai tautan aktif. Untuk runtime, ancaman muncul jika file unggahan berakhir pada direktori yang diproses interpreter. Model

ancaman ini memandu pilihan skenario; status temuan baru ditetapkan setelah hasil nyata tersedia. Penyusunan tabel ancaman tidak diperlakukan sebagai lokakarya formal dengan stakeholder organisasi.

2.2.4. Vulnerability Analysis

Setiap dugaan diperiksa terhadap kebijakan dan implementasi. Status HTTP 200 saja tidak membuktikan IDOR tanpa kecocokan pemilik dan isi; payload tersimpan belum membuktikan XSS lintas akun; upload berhasil belum membuktikan eksekusi kode. Kriteria tersebut dipakai untuk menyeleksi bukti akhir. Source review mendukung penjelasan akar masalah, sedangkan kontrol pembanding menilai apakah temuan dipicu oleh mekanisme yang benar.

2.2.5. Exploitation

VULN-01 menggunakan dua akun staf dengan kepemilikan berbeda. VULN-02 menggunakan akun staf sebagai pembuat tautan dan admin sebagai pengguna yang mengaktifkannya. VULN-03 menggunakan marker PHP yang menghitung ekspresi sederhana. Pemilihan marker membuat keberhasilan dapat dikenali tanpa menjalankan perintah sistem operasi. Screenshot dicatat dalam urutan alur masing-masing temuan, dengan ID dokumen manual yang dipertahankan pada narasi.

2.2.6. Post-exploitation

Tahap ini dibatasi pada evaluasi akses yang telah didapat. Dokumen lain terbaca, script aktif dalam browser admin, dan PHP berjalan pada runtime aplikasi. Kemampuan lanjutan dibahas sebagai potensi dengan prasyaratnya. Tidak dilakukan pembuktian persistence, lateral movement, eksfiltrasi, penghentian layanan, atau akses root. Pembatasan ini menjaga ketepatan kesimpulan sekaligus memenuhi tujuan assessment.

2.2.7. Reporting

Temuan ditulis dengan judul, severity, endpoint, prasyarat, langkah reproduksi, expected/actual result, bukti, akar masalah, dampak, rekomendasi, dan kriteria retest. Statistik dihitung berdasarkan tiga akar masalah unik; dua test case upload tetap merujuk satu finding. Bukti manual, snapshot validasi lama, hasil tambahan, dan review source diberi asal yang berbeda. Penyajian ringkasan eksekutif serta detail teknis mengikuti kebutuhan pembaca sebagaimana panduan reporting PTES.

2.3. Teknik, tools, dan asal pengetahuan

Tool / teknik	Penggunaan yang dapat dipertanggungjawabkan	Batas dokumentasi
Brave dan Chrome pada screenshot manual	Navigasi dua akun staf, admin, dialog JavaScript, dan output PHP	Nama browser terlihat; nomor versi manual tidak direkam
Review PHP, JavaScript, Apache, Compose	Analisis otorisasi, URL, upload, storage, dan profil	Analisis source; tidak menggantikan bukti eksploitasi
Python 3 / urllib / unittest	Tes API dengan sesi, CSRF, dan assertion hasil	Ringkasan assertion, bukan ekspor raw HTTP Burp
Chromium / Playwright 1.56.0	Pengujian lintas konteks browser, gambar, PHP, dan alur admin	Run otomatis terpisah dari pengujian manual
Docker CLI dan inspeksi database	Versi runtime, image ID, serta metadata objek manual	Baca metadata; tidak mencatat password atau token
Python-docx	Penyusunan laporan Word	Pengolahan dokumen, bukan alat pengujian keamanan
Burp Suite, Nmap, ZAP, Nikto, WAF scanner	Tidak dinyatakan digunakan sebagai dasar temuan	Tidak ada artefak keluaran tool tersebut pada evidence manual

2.4. Rules of Engagement

- Target permintaan dibatasi pada tiga layanan loopback yang dijelaskan dalam scope.
- Akun uji disediakan pada staging; tindakan perubahan state dilakukan pada dokumen uji milik akun yang sesuai.
- Pengujian menggunakan perubahan identifier, tautan marker, serta file marker benign; tidak memakai perintah OS atau shell.
- Pengujian dihentikan jika layanan tidak responsif, data nyata muncul, atau request berpindah ke target di luar scope. Kondisi tersebut menjadi dasar penghentian dan eskalasi kepada pemilik lingkungan.
- Bukti manual dipertahankan; validasi tambahan memakai artefak uji terpisah. Tidak dilakukan reset massal saat penyusunan laporan.
- Jadwal remediasi, persetujuan perubahan, dan penerimaan risiko ditetapkan oleh pemilik aplikasi dan tim teknologi informasi.

2.5. Severity teknis dan CVSS v3.1

CVSS v3.1 menyediakan kerangka skor teknis yang dipakai secara konsisten untuk ketiga finding. Vector lengkap dan alasan pemilihan metrik dicantumkan pada detail masing-masing temuan. Laporan mempertahankan CVSS v3.1 sebagai versi penilaian dan tidak mengklaimnya sebagai versi CVSS terbaru. Referensi metodologis terdapat pada bagian Referensi Singkat.

Kategori teknis	Rentang skor
Critical	9.0–10.0
High	7.0–8.9
Medium	4.0–6.9
Low	0.1–3.9
None	0.0

Alasan metrik didasarkan pada skenario yang diuji. Untuk VULN-02 dan VULN-03, penilaian kemampuan script/kode mencakup konsekuensi teknis yang secara wajar tersedia dalam otoritas terkait; konsekuensi tersebut tetap dibedakan dari tindakan yang benar-benar dijalankan. Observasi tanpa dampak terpisah tidak diberi skor numerik secara paksa. Confidence bukti eksekusi tidak sama dengan tingkat keluasan dampak yang sudah dieksperimenkan.

2.6. Dampak dan dasar prioritas perbaikan

Severity teknis dinilai dengan CVSS v3.1. Dampak terhadap data dan proses bisnis dijelaskan secara naratif berdasarkan bukti, sensitivitas dokumen, kemampuan awal pelaku, kebutuhan interaksi korban, serta kewenangan runtime aplikasi. Dampak terkonfirmasi dibedakan dari kemampuan lanjutan yang dinilai atau belum diuji.

Prioritas penanganan disusun sebagai P1, P2, dan P3 pada BAB 4.3. Urutan ini mempertimbangkan severity teknis dan konteks aplikasi; prioritas bukan skor tambahan. Jadwal remediasi dan keputusan penerimaan risiko tetap ditetapkan oleh pemilik aplikasi.

BAB 3 BATASAN DAN KENDALA

3.1. Batas target dan representativitas

Assessment mencakup aplikasi RuangSurat pada staging dengan endpoint loopback yang tercantum dalam scope. Lingkungan tersebut dipakai untuk validasi praproduksi menggunakan akun dan data uji terkontrol. Production, domain di luar scope, host Windows/WSL, serta daemon Docker tidak menjadi target penetrasi. Hasil berlaku untuk build, konfigurasi, role, dan skenario yang didokumentasikan; perubahan saat deployment harus melalui verifikasi konfigurasi ulang.

3.2. Keterbatasan evidence manual

Screenshot menunjukkan keadaan antarmuka, identitas akun yang sedang aktif, isi dokumen, address bar pada sebagian gambar, dialog browser, dan output marker. Screenshot tidak menyediakan seluruh HTTP request/response, nilai cookie, timestamp capture yang terverifikasi, atau transkrip login. Karena itu, contoh HTTP pada detail temuan secara eksplisit disebut rekonstruksi dari endpoint implementasi; status HTTP tertentu berasal dari tes tambahan, bukan dibaca dari screenshot.

Pada VULN-01, gambar bernama `4_login pada akun kedua.png` sudah menampilkan Bima berada pada dokumen Alya. Nama file mengisyaratkan pergantian akun tetapi tidak merekam transaksi login. Gambar `5_modify id endpoint.png` menunjukkan pengisian `/documents/12` pada address bar sementara halaman di belakang masih dokumen Bima RS-004; gambar tersebut tidak membuktikan respons akhir. Gambar keenam merupakan bukti akhir akses lintas pemilik. Perbedaan fungsi setiap gambar dijelaskan agar urutan tidak dibaca sebagai transkrip jaringan yang lengkap.

Pada VULN-02, eksekusi memerlukan klik pada tautan. Dialog tidak muncul otomatis hanya karena halaman dibuka. Istilah “tidak sengaja memencet” pada nama file tidak membuktikan clickjacking atau pemaksaan interaksi; kesimpulan yang dipakai adalah admin mengaktifkan tautan yang memuat skema JavaScript.

3.3. Keterbatasan build dan waktu

Tag `ruangsurat-1.1/:1.1` dipakai ulang ketika fitur pratinjau gambar dan tautan eksekusi PHP ditambahkan selama sesi kerja. Oleh sebab itu, tag tidak diperlakukan sebagai identifier immutable. VULN-03 manual sudah memperlihatkan label “Jalankan PHP”, sedangkan gambar VULN-01 dan VULN-02 tidak cukup untuk menentukan image ID historis masing-masing. Image ID yang direkam saat penyusunan mengidentifikasi build yang diperiksa dan divalidasi tambahan; tidak secara retroaktif menentukan build seluruh screenshot lama.

Hash source dan image ID membantu mereproduksi keadaan saat pencatatan. Tidak tersedia commit Git yang dapat diandalkan dari snapshot workspace; laporan tidak membuat nilai commit buatan. Tanggal pembuatan objek dari database dipisahkan dari tanggal screenshot dan waktu retest.

3.4. Perbedaan data antar-run

ID manual utama adalah 12, 15, dan 19 pada profil vulnerable. Snapshot validasi lama dan skrip otomatis memakai objek awal pengujian atau dokumen yang dibuat sendiri, sehingga ID-nya berbeda. Penolakan pada fixed diperoleh dengan sesi serta objek milik akun yang valid pada fixed; bukan mengasumsikan ID 12/15/19 vulnerable mempunyai pemilik yang sama pada database fixed. Perbedaan itu tidak mengurangi nilai kontrol pembanding sepanjang prasyaratnya dicatat.

3.5. Area yang tidak diuji

Area	Status / alasan
TLS, HTTPS, sertifikat, dan cipher	Di luar scope HTTP lokal; tidak dinilai

Area	Status / alasan
Brute force dan ketahanan rate limit	Tidak diuji secara menyeluruh
SQL injection menyeluruh, fuzzing parser, dan race condition	Tidak ada kampanye uji khusus; satu assertion login bukan audit kelas kelemahan
Eksfiltrasi data, aksi admin lewat XSS, dan takeover akun	Tidak dibuktikan oleh dialog marker
Perintah OS, shell, persistence, eskalasi root, container escape	Tidak dilakukan; marker PHP hanya menghitung ekspresi
DoS, penghapusan database, dan modifikasi data massal	Tidak dilakukan
Semua variasi file/polyglot dan seluruh bypass browser	Tidak tercakup; retest dibatasi fixture yang disebutkan
Review independen dan persetujuan rilis	Tidak ada bukti yang disertakan

3.6. Konsekuensi terhadap kesimpulan

Laporan menyimpulkan tiga temuan dengan batas yang jelas, bukan bahwa seluruh aplikasi telah diaudit atau dinyatakan aman. Hasil negatif berlaku pada request, role, dan variasi yang diperiksa. Pernyataan Fixed selalu dikaitkan dengan profil fixed dan skenario terkait. Pengujian tidak mencakup kuantifikasi kerugian finansial; konsekuensi bisnis perlu ditinjau berdasarkan klasifikasi dokumen dan eksposur deployment. Potensi dampak tinggi pada runtime tidak sama dengan pembuktian akses root atau pengambilalihan host.

BAB 4 RINGKASAN TEMUAN

4.1. Daftar temuan terkonfirmasi

ID	Judul	CVSS v3.1	Severity teknis	Status vulnerable
VULN-01	IDOR: Bima membaca dokumen Alya melalui identifier pada URL	4.3	Medium	Open — baseline staging
VULN-02	Stored XSS melalui skema JavaScript pada tautan referensi	5.4	Medium	Open — baseline staging
VULN-03	Upload executable: lampiran PHP diproses interpreter server	8.8	High	Open — baseline staging

4.2. Statistik dan rekonsiliasi

Severity teknis	Jumlah	Persentase dari tiga temuan
Critical	0	0,00%
High	1	33,33%
Medium	2	66,67%
Low	0	0,00%
Total	3	100,00%

Satu akar masalah upload dipetakan ke dua test case WSTG, BUSL-08 dan BUSL-09, tanpa dihitung menjadi dua finding. Dua observasi pendukung juga tidak masuk penyebut statistik. Persentase di atas menggunakan severity teknis CVSS. Dampak dan alasan prioritas penanganan dijelaskan secara naratif.

4.3. Prioritas remediasi

Urutan	Finding	Penanggung jawab fungsi yang disarankan	Hasil yang dituju
P1	VULN-03	Pengembang backend dan pengelola web server	File pengguna tidak dieksekusi; upload normal tetap berjalan
P2	VULN-01	Pengembang backend	Akses baca selalu memeriksa pemilik/admin
P3	VULN-02	Pengembang backend/frontend	URL aktif berbahaya ditolak dan data lama dirender aman

Prioritas mempertimbangkan luas kemampuan teknis dan dampak terhadap dokumen serta proses administrasi. Pengelolaan upload menjadi P1, otorisasi objek menjadi P2, dan validasi URL menjadi P3. IDOR didahulukan dari XSS karena staf dapat memicu pembacaan dokumen tanpa interaksi korban, sementara XSS memerlukan klik admin. Urutan ini tidak mengubah skor CVSS masing-masing temuan. Seluruh kontrol perlu masuk ke kandidat rilis yang sama dan diverifikasi pada staging. Konfigurasi baseline yang masih rentan tidak direkomendasikan untuk dipromosikan ke production.

4.4. Ringkasan keadaan pembanding

Finding	Bukti manual vulnerable	Hasil fixed pada tes tambahan	Kesimpulan terbatas
VULN-01	Dokumen Alya tampil pada sesi Bima	Akses lintas pemilik ditolak; pemilik/admin tetap dapat membaca	Fixed pada skenario otorisasi baca yang diuji
VULN-02	Admin melihat dialog PENTEST_02	Penyimpanan JavaScript ditolak; tautan legacy dinonaktifkan	Fixed pada skema dan fixture yang diuji
VULN-03	marker.php tersedia dan menghasilkan EXECUTED_5	PHP, konten PHP tersamar TXT, dan gambar palsu ditolak	Fixed pada variasi upload yang diuji

BAB 5 TECHNICAL DETAILS

5.1. Information Gathering dan analisis lingkungan

5.1.1. Teknologi dan sumber identifikasi

Inspeksi runtime saat penyusunan mencatat PHP 8.4.26 dan Apache 2.4.68 (Debian). Source menggunakan PDO SQLite dan session PHP; JavaScript frontend memakai `fetch()` untuk memanggil API. Tidak diperlukan Composer, npm, atau CDN untuk fungsi aplikasi. Informasi tersebut diperoleh dari perintah runtime serta source/config. Laporan tidak menganggap banner screenshot sebagai bukti versi yang tidak terlihat.

Konfigurasi Compose mempublikasikan vulnerable pada 127.0.0.1:8080, fixed pada 127.0.0.1:8081, serta PoC pada 127.0.0.1:8090. Container aplikasi berjalan sebagai `www-data`, memiliki root filesystem read-only dan storage melalui volume. Pengaturan ini membatasi beberapa kemampuan pada level container, tetapi direktori writable masih cukup untuk menyimpan dokumen dan lampiran. VULN-03 dinilai pada otoritas aplikasi tersebut, bukan otoritas root host.

5.1.2. Endpoint yang relevan

Method / path	Fungsi / parameter utama	Kontrol yang relevan
GET /api/session	Identitas sesi, mode, build, dan token CSRF	Menyiapkan sesi pengujian tanpa menyalin token ke laporan
POST /api/login	email, password	Autentikasi; regenerasi session ID
GET /api/documents	Daftar pengajuan	Daftar staf dibatasi ke pemilik
GET /documents/{id}	Halaman detail	Jalur manual VULN-01
GET /api/documents/{id}	Detail JSON	Pembanding otorisasi pada tes API
POST /api/documents/{id}/links	label, url	VULN-02; URL disimpan di dokumen
POST /api/documents/{id}/attachments	multipart file	VULN-03; file dipindahkan ke storage
GET /uploads/{stored}.php	Jalur publik di vulnerable	Diproses Apache/PHP pada skenario yang diuji
GET /api/attachments/{id}/download	Unduhan source/data	Otorisasi pemilik/admin; attachment disposition
GET /api/attachments/{id}/preview	Pratinjau PNG/JPG	Otorisasi dan pemeriksaan gambar asli
POST /api/documents/{id}/submit	Pengiriman draft	Pemilik draft; sesudah submit edit dibatasi
POST /api/documents/{id}/approve atau /reject	Keputusan	Hanya admin dan status submitted
GET /api/admin/users	Direktori pengguna	Hanya admin
POST /api/logout	Mengakhiri sesi	Akses API sesudah logout harus ditolak

5.1.3. Sesi, header, dan kontrol pembanding

Source menetapkan cookie sesi dengan HttpOnly dan SameSite=Lax, serta nama yang dibedakan per profil. Request POST memakai token CSRF. Tes API memeriksa penolakan perubahan tanpa token, penolakan direktori admin bagi staf, dan berakhirnya akses sesudah logout. Cookie bernilai Secure tidak dijadikan klaim karena akses staging yang diuji menggunakan HTTP. HttpOnly menghambat pembacaan cookie dari JavaScript,

tetapi tidak menghentikan script yang sudah berjalan untuk berinteraksi dengan halaman pada konteks browser terkait.

Fixed menambahkan CSP termasuk `script-src 'self'`, `frame-ancestors 'none'`, serta X-Frame-Options DENY. Endpoint download menggunakan attachment disposition dan sandbox. Endpoint preview gambar menggunakan tipe MIME gambar terverifikasi. Nilai token/cookie tidak disimpan pada contoh request dalam laporan. Bukti header/detail respons jaringan berasal dari tes atau konfigurasi, bukan dari gambar antarmuka.

5.1.4. Storage dan keterkaitannya dengan VULN-03

Profil	Lokasi di container	Volume / lokasi host Docker
Baseline staging	/var/www/html/public/uploads	Volume persisten untuk lampiran publik; konfigurasi mount pada compose.yaml
Kandidat perbaikan	/var/lib/ruangsurat/uploads	Volume data privat dengan subfolder uploads; konfigurasi mount pada compose.yaml
Database masing-masing profil	Direktori /var/lib/ruangsurat/	Database SQLite pada volume data terpisah untuk setiap profil

Lampiran dan database berada pada volume persisten Docker yang dipisahkan untuk baseline staging serta kandidat perbaikan. Direktori publik baseline dapat dijangkau melalui web server, sedangkan storage kandidat perbaikan berada di luar document root. Nama file disimpan secara acak; nama asli, MIME, ukuran, dan relasi dokumen dicatat pada tabel attachments. Konfigurasi penyimpanan dapat diperiksa pada compose.yaml dan docker/apache.conf.

Kelemahan VULN-03 berasal dari penggabungan penerimaan tipe executable dengan lokasi publik yang mempunyai handler PHP. Mengganti nama menjadi acak tidak menghilangkan handler pada ekstensi `.php`. Perbedaan “Unduh file PHP” dan “Jalankan PHP” pada tampilan terbaru hanya menentukan URL yang dibuka; akar masalahnya sudah berada pada upload dan konfigurasi server.

5.1.5. Threat model

Batas kepercayaan	Aset / pelaku	Hipotesis yang diuji	Kontrol yang diharapkan
Staf → objek pengguna lain	Dokumen Alya; akun Bima	Identifier dapat diganti untuk membaca objek Alya	Verifikasi pemilik/admin pada setiap pembacaan
Input staf → browser admin	Tautan; sesi Nadia	Skema JavaScript tersimpan dan diaktifkan korban	Allowlist URL, encoding, dan render legacy aman
File pengguna → interpreter	Lampiran; runtime PHP	PHP tersimpan dalam web root dan diproses server	Allowlist file, private storage, larangan handler

Ketiga hipotesis dikonfirmasi melalui bukti pada bagian berikut. Tidak ditambahkan skenario host compromise sebagai hasil hanya karena salah satu batas kepercayaan aplikasi gagal.

5.2. Security Findings

5.2.1. VULN-01 — IDOR pada pembacaan dokumen pengguna lain

Metadata temuan	Keterangan
ID / kategori	VULN-01 / Broken Access Control; horizontal authorization bypass
Severity teknis	Medium; CVSS v3.1 4.3
Vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N
Status	Open pada vulnerable; Fixed pada skenario pembanding fixed
Target manual	http://127.0.0.1:8080/documents/12
Parameter	Identifier numerik pada path dokumen
Pemilik / pelaku uji	Alya Pratama / Bima Saputra; keduanya staf
Objek uji	RS-012; PENTEST_01 Surat Tugas Pergi ke Jerman
Tanggal / bukti	22 Oktober 2026; EV-001 sampai EV-006
Pemetaan	CWE-639; A01:2025 Broken Access Control; WSTG-v42-ATHZ-04

Deskripsi dan akar masalah

Halaman detail mengambil identifier dari URL dan memuat dokumen terkait. Pada profil vulnerable, fungsi `document()` mempunyai pengecualian untuk pembacaan tanpa pemeriksaan kepemilikan yang melewatkan pemeriksaan kepemilikan. Akibatnya, Bima yang sudah login dapat memasukkan ID dokumen Alya dan memperoleh isi dokumen tersebut. Pengguna tidak perlu mengetahui password Alya, mengubah cookie menjadi admin, atau mendapatkan hak lebih tinggi. Kelemahan merupakan kegagalan otorisasi horizontal terhadap objek.

Source memperlihatkan bahwa daftar dashboard staf tetap difilter berdasarkan `owner_id`, sedangkan jalur detail browser dan API mengizinkan pengecualian pembacaan pada vulnerable. Perbedaan ini menjelaskan mengapa menu atau daftar yang terlihat terbatas belum cukup melindungi objek yang diminta langsung. ID yang berurutan mempermudah penemuan objek, tetapi akar masalahnya adalah pemeriksaan hak akses yang dilewati, bukan penggunaan bilangan bulat itu sendiri.

Prasyarat dan hasil yang diharapkan

Penguji menggunakan dua sesi staf yang berbeda. Alya membuat dokumen, kemudian Bima membuka URL yang menunjuk dokumen Alya. Expected result adalah penolakan tanpa isi dan metadata dokumen, misalnya 404 agar tidak sekaligus mengungkap keberadaan objek. Actual result pada bukti akhir adalah judul, nama Alya sebagai pengaju, dan isi surat tugas tampil sementara sidebar menunjukkan Bima sebagai pengguna aktif.

Langkah reproduksi

1. Login sebagai Alya pada profil vulnerable dan buat pengajuan surat tugas. Isi judul serta keterangan sesuai EV-001.

2. Simpan draft dan catat ID yang diberikan aplikasi. Pengajuan manual memperoleh ID 12 dan menampilkan pemilik Alya.

3. Kirim pengajuan; pada EV-003 dokumen berstatus Menunggu review dan URL menunjukkan `/documents/12`.

4. Gunakan browser/sesi berbeda dengan akun Bima. Buka dokumen Bima sebagai pembanding, misalnya RS-004.

5. Masukkan `http://127.0.0.1:8080/documents/12` pada address bar dalam sesi Bima.

6. Setelah navigasi selesai, periksa bahwa halaman masih memakai identitas Bima namun menampilkan dokumen milik Alya. EV-006 adalah hasil akhir yang mendukung kesimpulan.

Bentuk request relevan

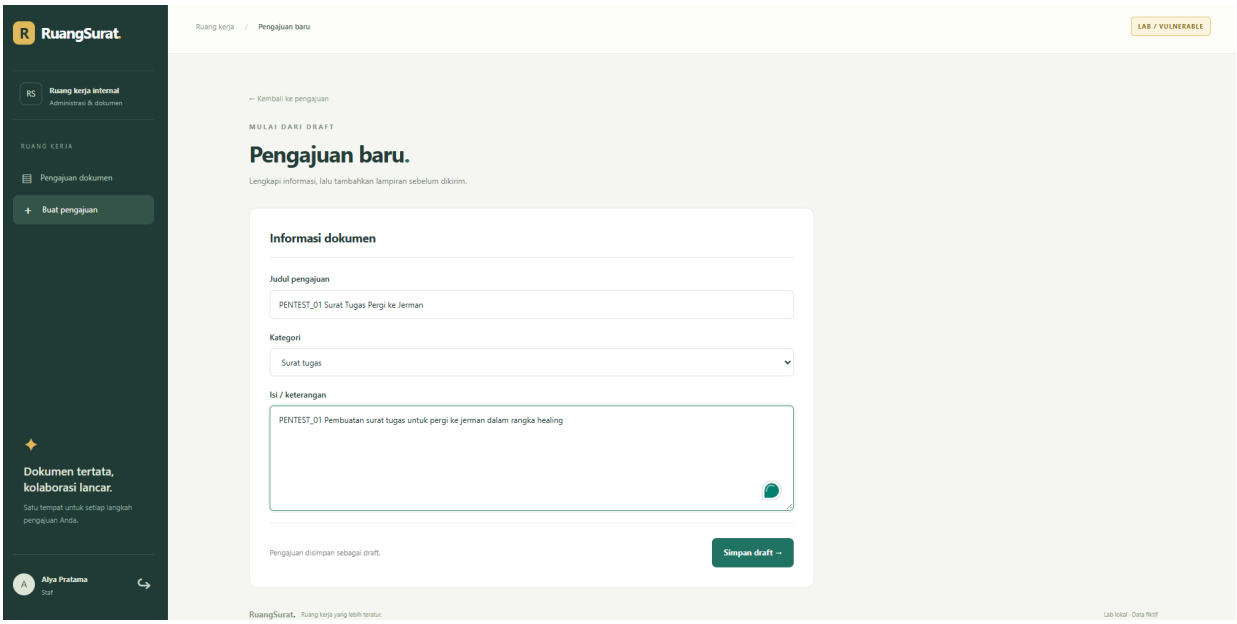
Contoh berikut adalah rekonstruksi minimal dari URL pada screenshot dan perilaku endpoint source; ini bukan ekspor raw HTTP dari pengujian manual.

```
GET /documents/12 HTTP/1.1
Host: 127.0.0.1:8080
Cookie: RUANGSURAT_VULNERABLE=[REDACTED]

Konteks sesi: Bima Saputra (staf).
Objek yang diminta: dokumen Alya Pratama.
```

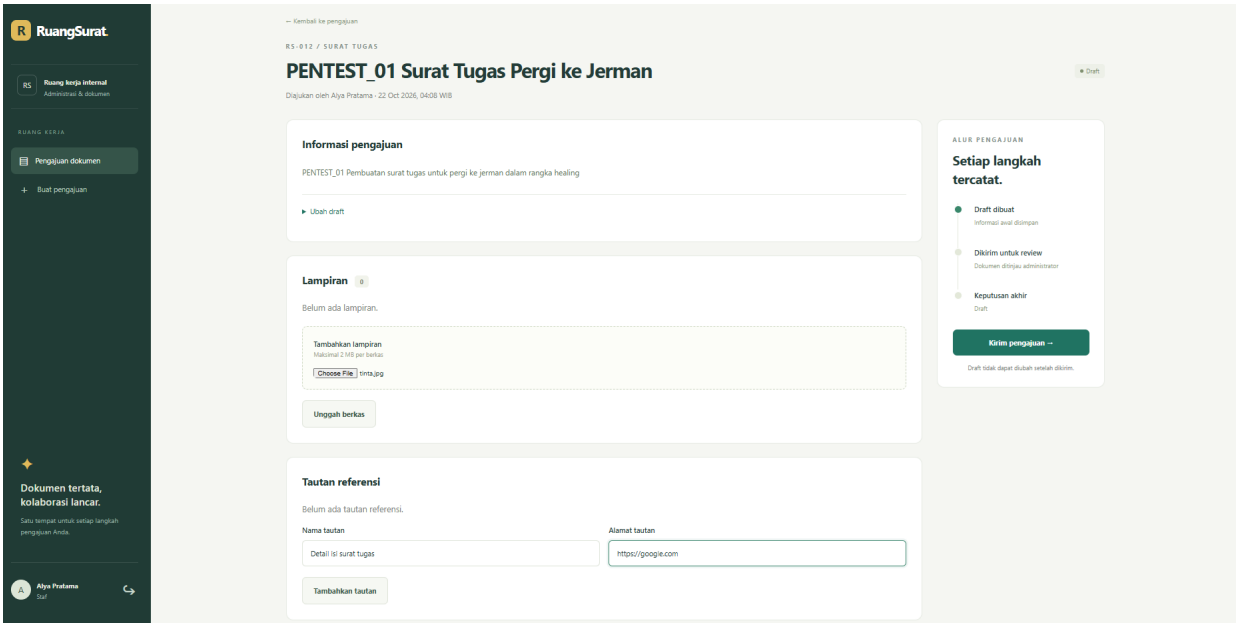
Hasil manual: isi dan metadata RS-012 terbaca. Status HTTP 200 untuk pola baca lintas pemilik dikonfirmasi oleh tes API/browser terpisah; angka tersebut tidak terlihat langsung pada screenshot EV-006.

Evidence VULN-01: pembuatan objek oleh Alya



Gambar 1 — EV-001: Alya mengisi pengajuan surat tugas pada profil vulnerable.

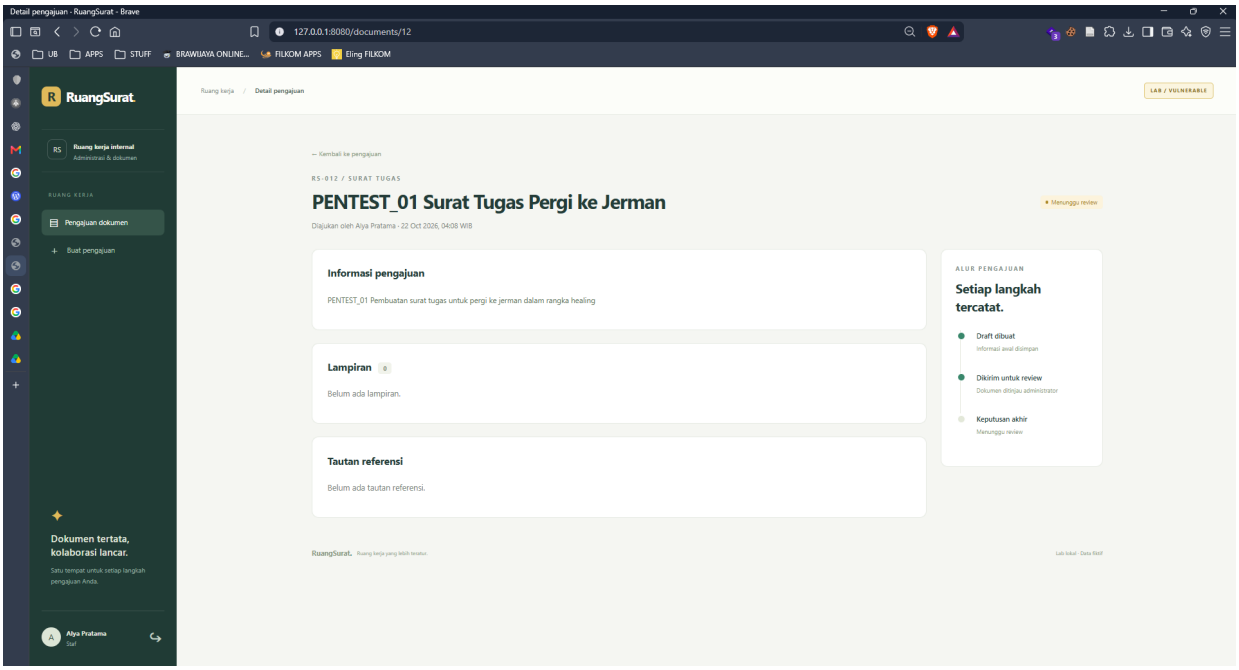
Judul pada form adalah “PENTEST_01 Surat Tugas Pergi ke Jerman”, kategori Surat tugas, dengan keterangan pembuatan surat tugas untuk pergi ke Jerman. Identitas Alya pada sidebar mengikat tindakan pembuatan kepada akun pemilik. Gambar ini menunjukkan persiapan objek; belum membuktikan bahwa objek disimpan maupun diakses pengguna lain.



Gambar 2 — EV-002: draft RS-012 dibuat atas nama Alya; jumlah lampiran masih nol.

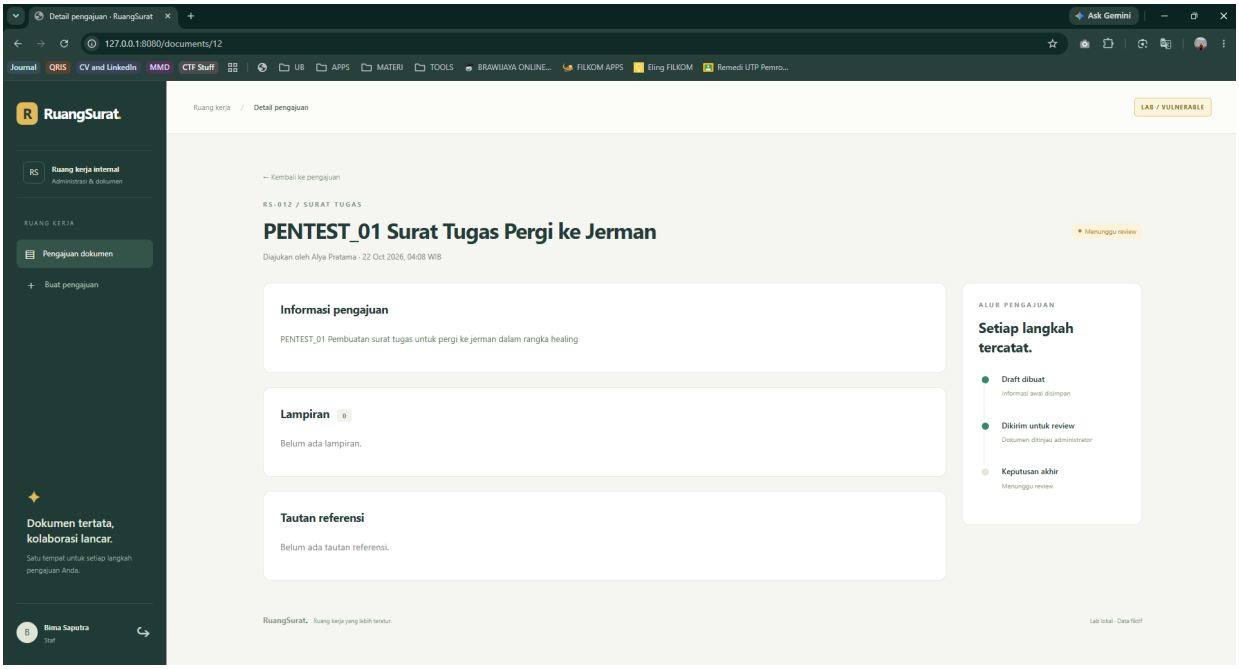
Halaman menampilkan RS-012, pemilik Alya, dan waktu pembuatan 22 Oktober 2026 pukul 04:08 WIB. Berkas `tinta.jpg` terlihat dipilih pada input tetapi jumlah lampiran tetap nol. Demikian juga tautan masih berada pada form. Karena itu, gambar tidak dipakai untuk mengklaim keberhasilan upload/penyimpanan tautan; fungsi bukti utamanya adalah mengikat judul dan ID kepada Alya.

Evidence VULN-01: URL pemilik dan pergantian konteks pengguna



Gambar 3 — EV-003: Alya membuka /documents/12; pengajuan berstatus Menunggu review.

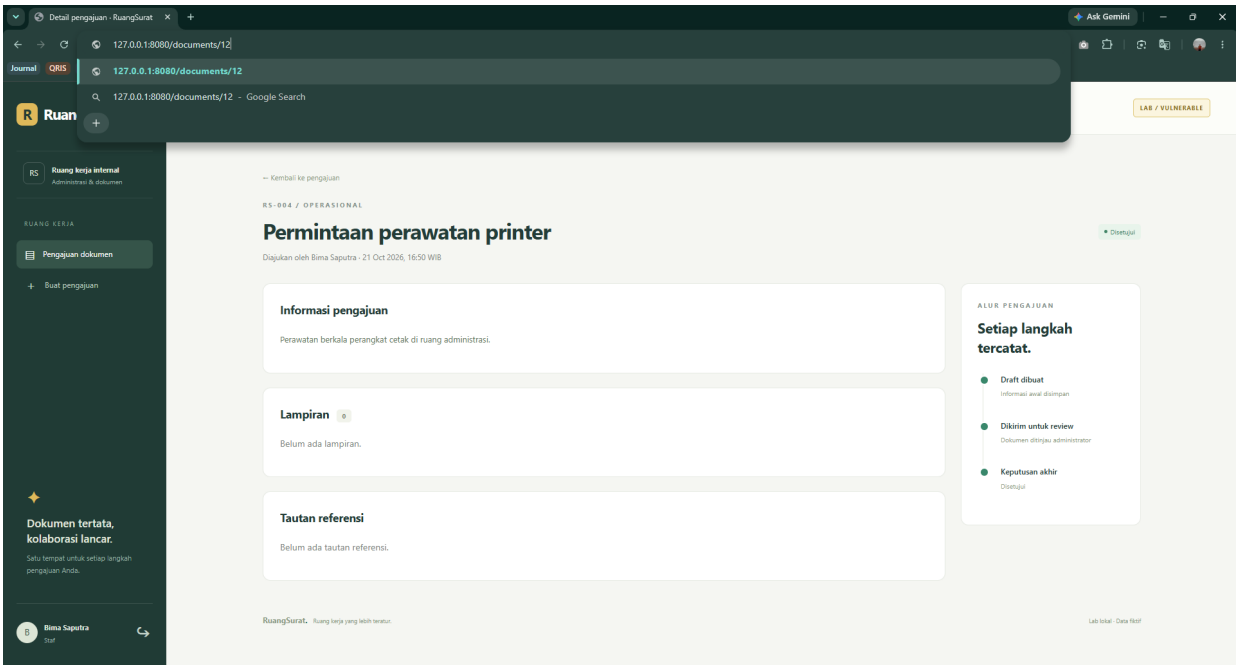
Address bar dan label RS-012 konsisten. Nama pengaju serta sidebar sama-sama Alya, sehingga pembacaan oleh pemilik merupakan baseline yang sah. Judul dan isi pada gambar ini menjadi pembanding terhadap hasil pada sesi Bima. Dokumen sudah dikirim; akses baca lintas pemilik tetap tidak dibenarkan oleh perubahan status menjadi submitted.



Gambar 4 — EV-004: identitas aktif Bima terlihat, sementara dokumen Alya sudah tampil.

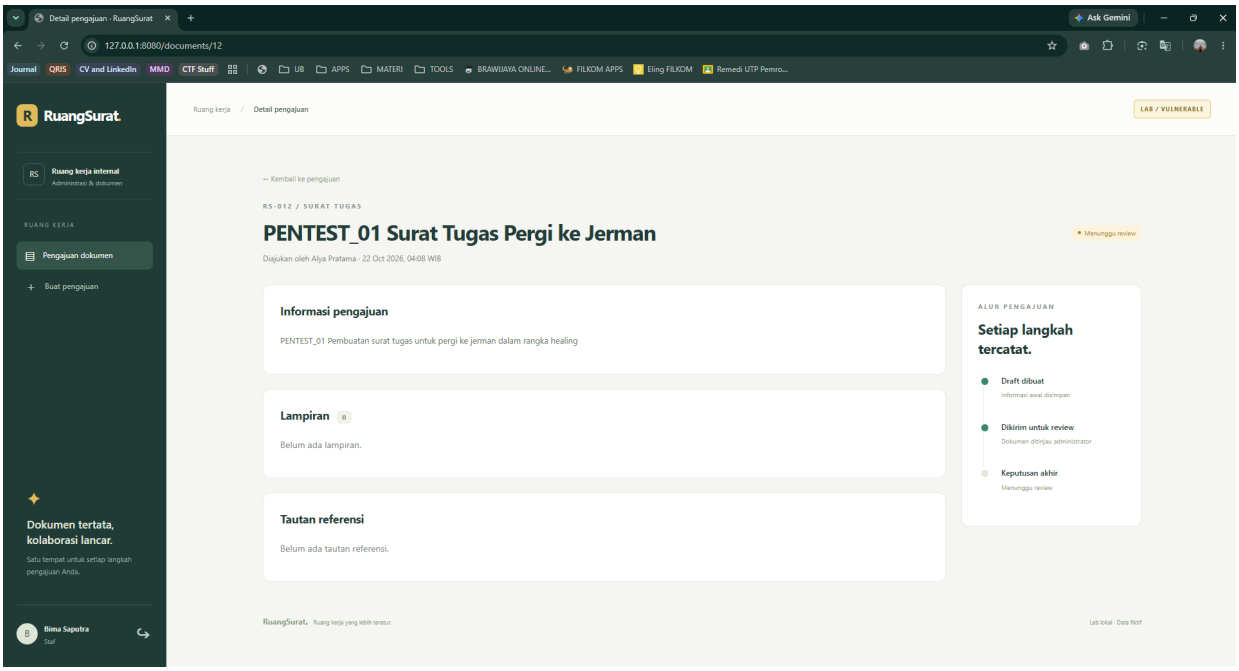
Meskipun nama file menyebut login akun kedua, screenshot ini merupakan keadaan sesudah login dan sesudah halaman tujuan tampil. Sidebar menunjukkan Bima, tetapi detail menyebut Alya sebagai pengaju RS-012. Gambar mendukung pemisahan identitas pelaku dari pemilik; transaksi login sendiri tidak direkam pada screenshot ini.

Evidence VULN-01: perubahan identifier dan hasil akhir



Gambar 5 — EV-005: Bima mengetik /documents/12 saat halaman di belakang masih RS-004 milik Bima.

Address bar dalam keadaan diedit menuju ID 12. Halaman belakang masih memperlihatkan “Permintaan perawatan printer”, RS-004, yang diajukan Bima. Bukti ini menunjukkan transisi dari objek milik sendiri ke identifier target. Karena navigasi belum selesai, tampilan di belakang tidak boleh dibaca sebagai respons server untuk ID 12.



Gambar 6 — EV-006: hasil akhir IDOR; Bima membaca judul, pengaju, dan isi dokumen Alya pada /documents/12.

Gambar ini merupakan bukti penentu: URL `/documents/12`, judul surat tugas, nama Alya sebagai pengaju, dan isi dokumen tampil bersama identitas Bima sebagai pengguna aktif. Pelanggaran kebijakan ditentukan oleh kombinasi tersebut. Tidak ada bukti bahwa Bima dapat mengubah, menyetujui, atau mengunduh lampiran Alya melalui endpoint terotorisasi.

Dampak dan batas pembuktian VULN-01

Dampak terkonfirmasi adalah pembacaan isi satu dokumen dan metadata pemilik oleh staf lain. Pada proses administrasi perusahaan, pola akses serupa berpotensi mengungkap informasi pengadaan, perjalanan dinas, atau kegiatan internal, sesuai sensitivitas dokumen. Pengujian memakai data staging terkontrol dan tidak melakukan ekstraksi massal. Uji tambahan menunjukkan bahwa perubahan dokumen dan unduhan lampiran melalui endpoint terotorisasi tetap ditolak; cakupan temuan dibatasi pada pembacaan detail.

Justifikasi CVSS VULN-01

Metrik	Nilai	Alasan skenario
AV	N	Permintaan dilakukan melalui HTTP terhadap aplikasi
AC	L	Tidak memerlukan kondisi kompleks; identifier dapat dimasukkan langsung
PR	L	Akun staf biasa diperlukan
UI	N	Pemilik dokumen tidak perlu melakukan tindakan saat akses dijalankan
S	U	Dampak berada pada otoritas aplikasi yang sama
C	L	Isi dan metadata dokumen uji terbaca di luar kepemilikan
I	N	Perubahan dokumen pengguna lain tidak dibuktikan
A	N	Tidak ada gangguan ketersediaan yang dibuktikan

Vector menghasilkan 4.3, Medium. Bukti menunjukkan isi dan metadata satu dokumen terbaca oleh staf lain tanpa tindakan pemilik. Dampak bisnis bergantung pada sensitivitas dokumen; perbaikan otorisasi menjadi P2.

Rekomendasi perbaikan VULN-01

- Hilangkan pengecualian otorisasi pembacaan untuk mode penggunaan normal. Setiap request harus memeriksa keberadaan dokumen dan kecocokan pemilik atau role admin sebelum mengembalikan data.
- Gunakan satu mekanisme otorisasi yang dipakai konsisten oleh halaman detail, API detail, unduhan, dan pratinjau. Hindari membuat jalur baru yang mengambil objek tanpa pemeriksaan yang setara.
- Jangan mengandalkan filter dashboard atau UUID sebagai pengganti otorisasi. Identifier acak dapat mengurangi penebakan, tetapi pengguna yang mengetahui ID tetap harus ditolak jika tidak berhak.
- Tambahkan regresi dengan pemilik, staf lain, admin, anonim, ID tidak ada, serta dokumen draft/submitted/approved. Pertahankan respons tanpa isi sensitif pada penolakan.
- Penanggung jawab fungsi yang disarankan: backend. Penerapan direkomendasikan sebelum rilis production; kontrol pembanding telah diverifikasi pada kandidat perbaikan.

Kriteria retest VULN-01

Dengan sesi staf A, dokumen staf B tidak boleh dikembalikan oleh halaman maupun API. Dengan sesi pemilik, isi tetap tersedia; dengan sesi admin, isi tersedia sesuai kebijakan. Anonim tidak memperoleh detail privat. Tes pembanding fixed memenuhi skenario tersebut. Untuk bukti manual Bima → Alya, penutupan temuan tidak dilakukan pada profil vulnerable karena pengecualian otorisasi pada baseline masih aktif pada baseline.

5.2.2. VULN-02 — Stored XSS melalui tautan referensi

Metadata temuan	Keterangan
ID / kategori	VULN-02 / Stored XSS dengan pemicu klik pada tautan
Severity teknis	Medium; CVSS v3.1 5.4
Vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:N
Status	Open pada vulnerable; Fixed pada skenario pembanding fixed
Endpoint simpan	POST /api/documents/{id}/links; field label dan url
Lokasi render manual	http://127.0.0.1:8080/documents/15
Pembuat / pengguna yang membuka	Alya Pratama (staf) / Nadia Putri (admin)
Objek uji	RS-015; PENTEST_02 Pengadaan Proyektor untuk Ruang Rapat H5.3
Payload manual	javascript:alert('PENTEST_02')
Tanggal / bukti	22 Oktober 2026; EV-007 sampai EV-011
Pemetaan	CWE-79; A05:2025 Injection; WSTG-v42-INPV-02

Deskripsi dan akar masalah

Fitur tautan memungkinkan staf menyimpan nama dan alamat referensi pada dokumen. Profil vulnerable menerima skema URI aktif, termasuk `javascript:`, lalu merender alamat tersebut pada atribut `href`. Encoding karakter HTML sudah digunakan untuk atribut, tetapi encoding tersebut tidak mengubah semantik skema JavaScript. Ketika admin mengklik tautan, browser menafsirkan alamat sebagai script dalam konteks halaman aplikasi.

Sifat stored berasal dari payload yang disimpan bersama dokumen dan kemudian ditampilkan kembali kepada pengguna lain. Penguji tidak hanya memasukkan script pada console lokalnya sendiri. Bukti memperlihatkan tahap input oleh Alya, tautan tersimpan, pembukaan dokumen oleh Nadia, dan dialog marker dalam sesi admin. Keperluan klik merupakan prasyarat penting; ini tidak diklaim sebagai eksekusi otomatis pada setiap page load.

Expected result dan actual result

Expected result: alamat dengan skema yang tidak sesuai kebutuhan bisnis ditolak ketika disimpan, atau dirender sebagai teks nonaktif apabila berasal dari data lama. Tautan HTTP/HTTPS yang sah tetap dapat dipakai. Actual result: URL JavaScript diterima, tampil sebagai “Detail Spesifikasi Proyektor”, dan memunculkan dialog `PENTEST_02` ketika dibuka admin pada origin `127.0.0.1:8080`.

Langkah reproduksi

1. Login sebagai Alya pada vulnerable dan buat draft pengadaan proyektor untuk ruang rapat H5.3.
2. Pada Tautan referensi, isi nama “Detail Spesifikasi Proyektor”.
3. Isi alamat dengan `javascript:alert('PENTEST_02')`, lalu klik Tambahkan tautan.
4. Pastikan tautan tersimpan pada RS-015, kemudian kirim pengajuan agar dapat ditinjau admin.
5. Login sebagai Nadia dengan sesi terpisah dan buka `/documents/15`.
6. Klik tautan referensi; periksa dialog marker. EV-011 menampilkan `PENTEST_02` dalam sesi admin.

Bentuk request dan hasil relevan

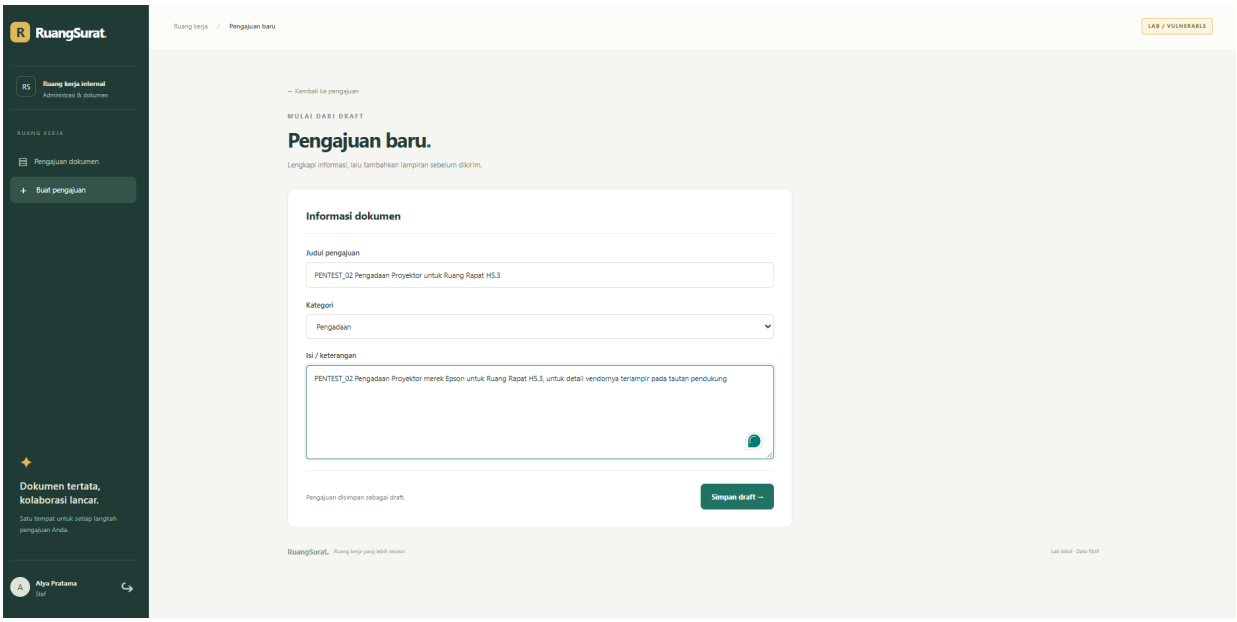
Contoh ini merupakan rekonstruksi endpoint dari source dan nilai input pada screenshot, bukan raw HTTP yang diekspor dari browser penguji.

```
POST /api/documents/15/links HTTP/1.1
Host: 127.0.0.1:8080
Cookie: RUANGSURAT_VULNERABLE=[REDACTED]
X-CSRF-Token: [REDACTED]
Content-Type: application/json

{"label":"Detail Spesifikasi Proyektor",
 "url":"javascript:alert('PENTEST_02')"}
```

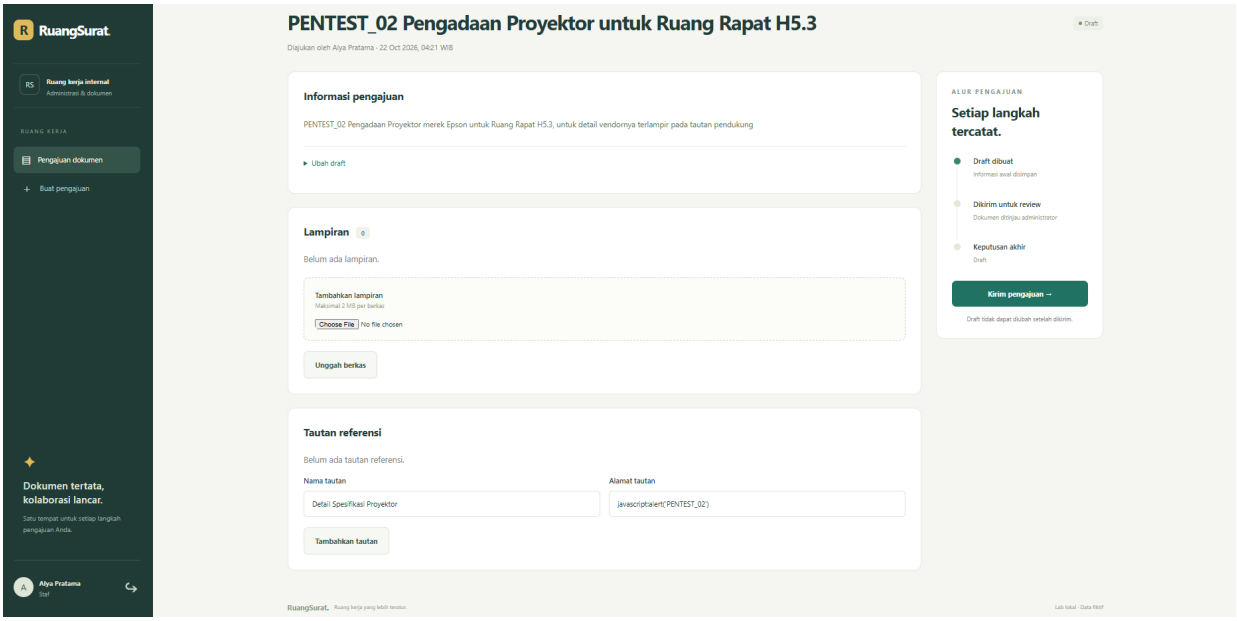
Hasil manual: tautan tersimpan dan dialog `PENTEST_02` muncul setelah klik admin. Tes API tambahan mengonfirmasi pola penerimaan 201 pada vulnerable dan penolakan 422 pada fixed menggunakan marker `RUANGSURAT_XSS`; marker tambahan tersebut berbeda dari payload manual dan tidak digabung sebagai satu transaksi.

Evidence VULN-02: draft pengadaan dan payload



Gambar 7 — EV-007: Alya menyiapkan pengajuan pengadaan proyektor dengan konteks tautan vendor.

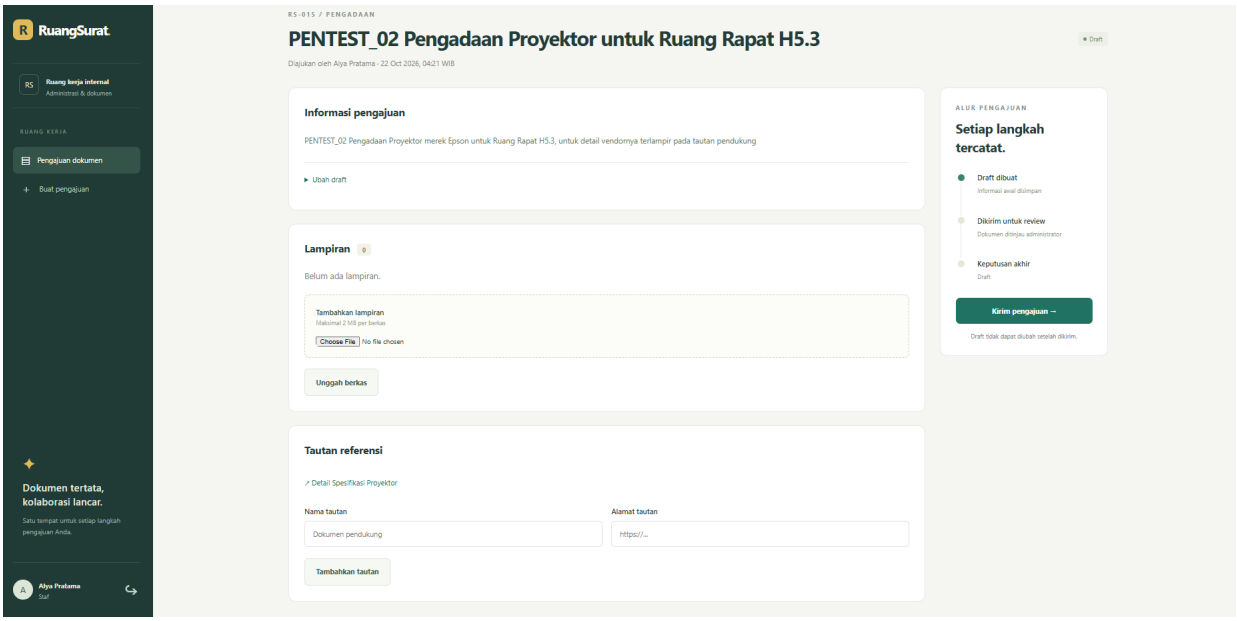
Form menunjukkan judul “PENTEST_02 Pengadaan Proyektor untuk Ruang Rapat H5.3” dan keterangan bahwa detail vendor ada pada tautan pendukung. Konteks ini menjelaskan mengapa admin secara wajar dapat membuka tautan referensi saat review. Gambar masih berupa persiapan pengajuan; tidak menyatakan bahwa vendor nyata diuji atau URL eksternal diakses.



Gambar 8 — EV-008: input javascript:alert('PENTEST_02') pada alamat tautan.

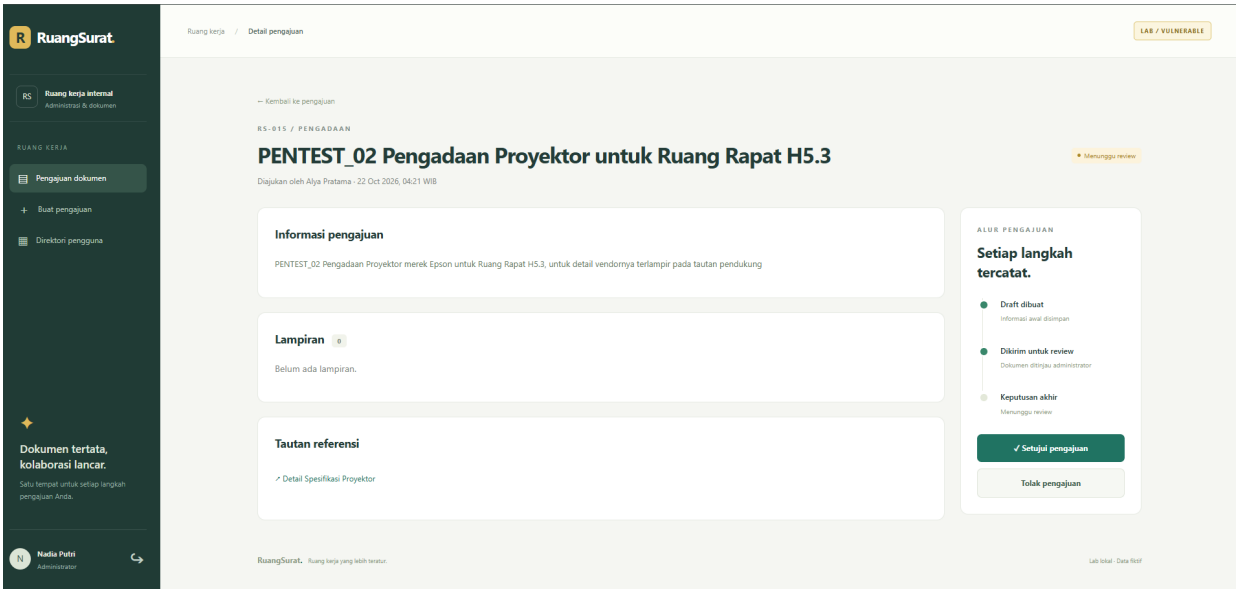
Nama tautan berisi “Detail Spesifikasi Proyektor”, sedangkan field alamat berisi skema JavaScript. Identitas aktif adalah Alya dan dokumen masih draft. Gambar membuktikan nilai yang dimasukkan; keberhasilan penyimpanan dan eksekusi dinilai melalui gambar berikutnya. Payload hanya memunculkan marker untuk membuktikan eksekusi.

Evidence VULN-02: persistensi payload dan paparan kepada admin



Gambar 9 — EV-009: tautan tersimpan sebagai referensi pada RS-015.

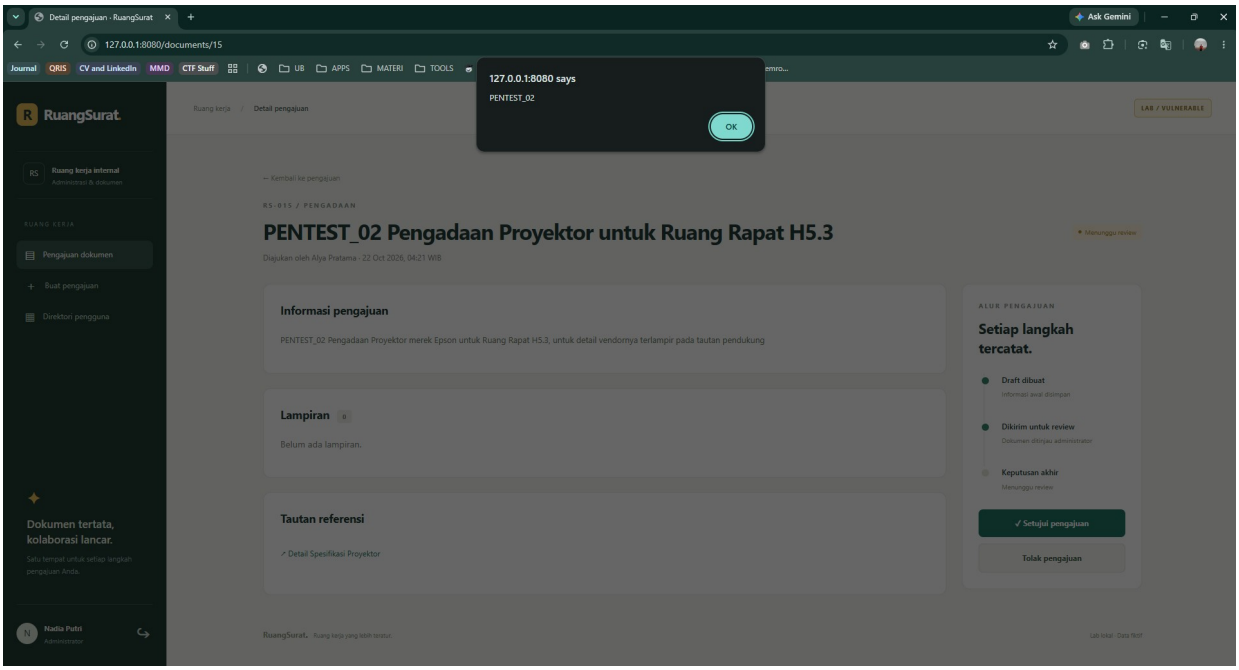
“Detail Spesifikasi Proyektor” sudah tampil dalam daftar referensi dan input form kembali kosong. Ini mendukung bahwa data telah dipersistensikan bersama dokumen. Tampilan nama tautan tidak memperlihatkan skema berbahaya kepada pembaca biasa; tetapi penyimpanan saja belum membuktikan bahwa browser akan mengeksekusi script.



Gambar 10 — EV-010: Nadia Putri membuka RS-015 dengan opsi persetujuan dan tautan referensi.

Sidebar menunjukkan Nadia Putri sebagai Administrator. Dokumen tetap menyebut Alya sebagai pengaju, berstatus Menunggu review, dan tautan referensi tersedia. Perbedaan identitas ini memperkuat aspek lintas akun. Tidak ada bukti pada gambar bahwa keputusan persetujuan sudah dijalankan atau dimanipulasi oleh payload.

Evidence VULN-02: eksekusi pada sesi administrator



Gambar 11 — EV-011: dialog PENTEST_02 muncul pada origin aplikasi dalam sesi Nadia.

Address bar menunjuk `/documents/15`. Dialog browser menyebut `127.0.0.1:8080 says` dan menampilkan `PENTEST_02`. Halaman di belakang memperlihatkan pengajuan Alya dan identitas Nadia sebagai administrator. Kombinasi ini membuktikan bahwa input staf yang tersimpan mencapai konteks browser admin dan dieksekusi setelah tautan diaktifkan.

Screenshot tidak memperlihatkan pencurian cookie, pembacaan endpoint privat, pengiriman data ke server lain, ataupun aksi persetujuan otomatis. Nama file yang menyebut klik tidak sengaja tidak mengubah klasifikasi menjadi clickjacking; tidak ada overlay atau pembingkaian menipu yang dibuktikan pada rangkaian ini.

Dampak terkonfirmasi dan potensial VULN-02

Dampak terkonfirmasi adalah JavaScript dapat berjalan pada halaman aplikasi dalam sesi admin melalui tautan yang dibuat staf. Kemampuan ini berpotensi memengaruhi informasi/tindakan yang tersedia kepada browser korban, bergantung kontrol aplikasi dan perilaku payload. Dialog marker tidak membuktikan seluruh potensi tersebut. HttpOnly menghalangi akses langsung ke nilai cookie melalui JavaScript, tetapi bukan perlindungan menyeluruh terhadap interaksi script dengan halaman yang sudah terautentikasi.

Tidak ada pembuktian takeover akun, transaksi sebagai admin, eksfiltrasi, atau dampak ketersediaan. Perbedaan antara kemampuan script dan dampak yang dieksperimenkan dipertahankan pada penilaian CVSS berikut.

Justifikasi CVSS VULN-02

Metrik	Nilai	Alasan skenario
AV	N	Input dan pemicu terjadi melalui layanan web
AC	L	Tidak memerlukan kondisi balapan atau lingkungan khusus
PR	L	Staf perlu mempunyai draft yang dapat diberi tautan
UI	R	Admin harus mengklik tautan yang tersimpan
S	C	Data aplikasi menimbulkan eksekusi dalam otoritas browser pengguna lain
C	L	Penilaian kemampuan script pada konteks korban; bukan klaim eksfiltrasi yang diuji
I	L	Penilaian kemampuan memengaruhi interaksi/konten korban; bukan bukti perubahan keputusan
A	N	Tidak ada dampak ketersediaan yang dinilai

Vector menghasilkan 5.4, Medium. C:L/I:L menilai kemampuan script pada browser korban; bukti primer berupa dialog marker. Pemicu membutuhkan klik admin, sehingga perbaikan menjadi P3. Pencurian data atau perubahan keputusan belum dibuktikan. Jika alur aplikasi memungkinkan tindakan bernilai tinggi, dampaknya perlu dinilai dengan bukti tambahan.

Rekomendasi perbaikan VULN-02

- Validasi alamat URL di server dengan allowlist skema HTTP dan HTTPS sesuai kebutuhan bisnis. Normalisasi dan periksa karakter kontrol/whitespace serta struktur URL sebelum penyimpanan.
- Jangan mengandalkan encoding atribut sebagai validasi skema. Pertahankan encoding HTML sesuai konteks, tetapi tolak `javascript:`, `data:`, serta skema aktif lain yang tidak diperlukan.
- Periksa ulang data yang sudah tersimpan saat render. Tautan lama yang tidak sesuai kebijakan sebaiknya menjadi teks nonaktif, sehingga perbaikan tidak hanya melindungi input baru.
- Terapkan CSP sebagai lapisan tambahan dan pertahankan pola DOM yang aman. Hindari mengisi HTML dari input pengguna tanpa sanitasi yang sesuai konteks.
- Tambahkan tes lintas role dengan konteks browser staf dan admin yang berbeda; uji payload tersimpan, variasi huruf/whitespace, data legacy, dan URL normal.
- Pemilik tindak lanjut fungsi: backend untuk validasi dan frontend untuk render. Target penyelesaian direkomendasikan sebelum rilis production dan dijadwalkan oleh pemilik aplikasi.

Kriteria retest VULN-02

Request penyimpanan skema JavaScript harus gagal karena validasi URL, bukan karena sesi/token yang salah. Tautan HTTP/HTTPS valid harus tetap dapat disimpan. Fixture data lama yang mengandung JavaScript tidak boleh menjadi anchor aktif. Ketika admin membuka pengajuan, dialog marker tidak boleh muncul dari tautan tersebut. Validasi tambahan fixed memenuhi skenario penyimpanan dan penonaktifan legacy; vulnerable masih memiliki jalur eksploitasi yang terkonfirmasi.

5.2.3. VULN-03 — Upload PHP menghasilkan eksekusi server

Metadata temuan	Keterangan
ID / kategori	VULN-03 / Unrestricted Upload of File with Dangerous Type
Severity teknis	High; CVSS v3.1 8.8
Vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Status	Open pada vulnerable; Fixed pada skenario pembanding fixed
Endpoint upload	POST /api/documents/19/attachments; multipart field file
Endpoint eksekusi manual	GET /uploads/37c64ddc2eea2f3ff6df28163342e2aa.php
Pembuat / objek	Alya Pratama / RS-019; PENTEST_03 Laporan Audit Keuangan PT Sigura-gura
File / ukuran	marker.php / 70 byte; metadata database mendukung screenshot
Tanggal / bukti	22 Oktober 2026; EV-012 sampai EV-014
Pemetaan	CWE-434; A02:2025 Security Misconfiguration; WSTG-v42-BUSL-08 dan BUSL-09

Deskripsi dan akar masalah

Profil vulnerable menerima file PHP sebagai lampiran dan menaruhnya pada `/var/www/html/public/uploads`. Direktori ini berada di bawah document root dan diproses web server dengan handler PHP. File memang diberi nama acak, tetapi ekstensi `.php` dipertahankan. Saat URL publik dibuka, Apache meneruskan file kepada interpreter sehingga kode dijalankan dan output dikirim ke browser.

Kelemahan mempunyai dua unsur yang saling melengkapi: validasi tipe executable tidak membatasi upload pada vulnerable, dan lokasi file memungkinkan eksekusi. Jika file hanya disimpan sebagai data di private storage serta dikirim melalui endpoint download, penerimaan file tidak otomatis menghasilkan eksekusi. Mapping A02:2025 pada laporan menekankan konfigurasi penyimpanan/handler, dengan CWE-434 sebagai klasifikasi teknis file berbahaya. Ini merupakan satu finding dengan beberapa kontrol yang gagal, bukan beberapa temuan baru berdasarkan setiap lapis mitigasi.

Prasyarat dan hasil yang diharapkan

Pengunggah mempunyai akun staf dan draft milik sendiri. Tidak diperlukan interaksi korban; pengunggah dapat membuka URL file sendiri setelah upload. Expected result adalah file PHP ditolak pada alur lampiran yang hanya membutuhkan dokumen/gambar, atau setidaknya disimpan di lokasi yang tidak pernah diproses interpreter. Actual result pada EV-013 adalah `marker.php` tercatat sebagai lampiran; EV-014 memperlihatkan output `EXECUTED_5` pada URL `.php` publik.

Payload benign dan alasan pembuktian

```
<?php
header('Content-Type: text/plain');
echo 'EXECUTED_' . (2 + 3);
```

Teks `EXECUTED_5` tidak muncul sebagai satu string literal utuh dalam source marker. Nilai lima berasal dari ekspresi yang dihitung PHP. Karena itu, respons yang menampilkan `EXECUTED_5` mendukung bahwa server memproses kode. Jika browser hanya mengunduh source atau menampilkan tag `<?php`, hasil tersebut tidak cukup untuk menyatakan eksekusi. Marker tidak menerima perintah pengguna dan tidak menjalankan perintah sistem operasi.

Langkah reproduksi VULN-03

1. Login sebagai Alya pada vulnerable dan buat draft laporan audit uji sebagaimana EV-012.

2. Simpan draft; objek manual memperoleh ID 19.

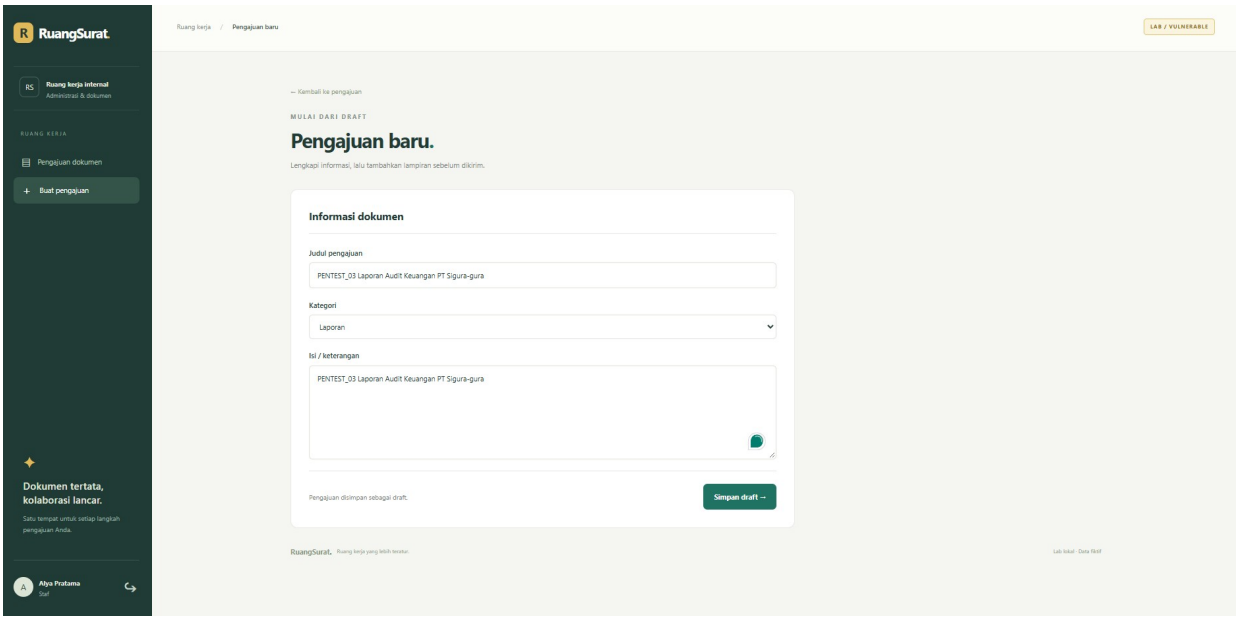
3. Pilih file `marker.php`, lalu klik Unggah berkas. Pastikan jumlah lampiran menjadi satu dan nama file tampil.

4. Klik nama lampiran yang bertanda “Jalankan PHP”, atau buka URL `/uploads/...php` yang dikembalikan aplikasi.

5. Periksa bahwa browser menampilkan `EXECUTED_5`. Ini merupakan output interpreter, bukan hasil membuka endpoint `/download`.

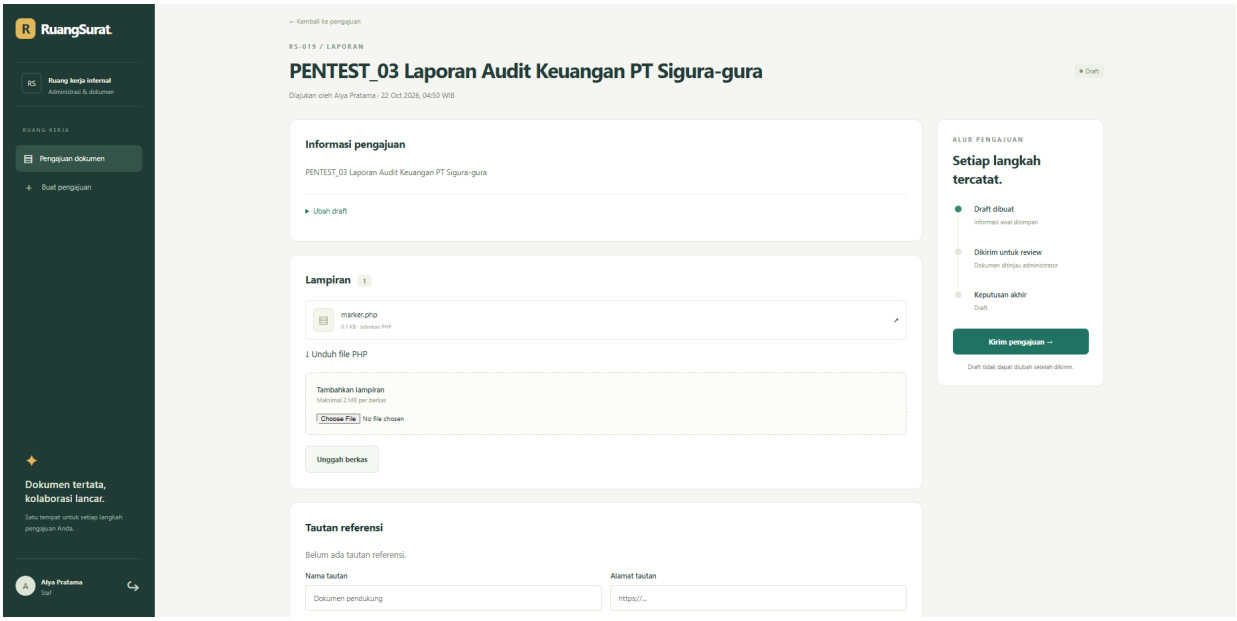
6. Bedakan tautan Unduh file PHP, yang mengirim source sebagai attachment, dari tautan nama file yang membuka URL publik executable.

Evidence VULN-03: pembuatan draft dan keberhasilan upload



Gambar 12 — EV-012: Alya menyiapkan laporan uji sebagai objek upload.

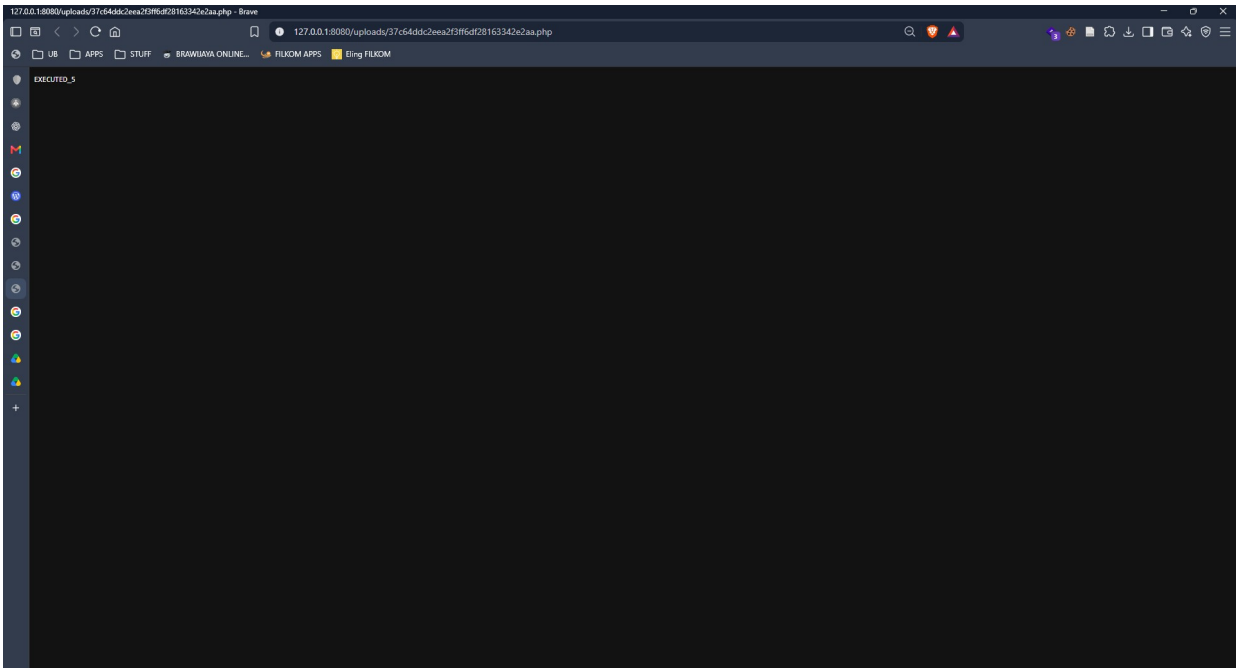
Form menggunakan kategori Laporan dan judul “PENTEST_03 Laporan Audit Keuangan PT Sigura-gura”. Judul berfungsi mengidentifikasi objek uji, sedangkan identitas Alya pada sidebar menunjukkan bahwa upload dilakukan menggunakan akun staf biasa. Penilaian tetap berfokus pada keamanan fungsi lampiran RuangSurat.



Gambar 13 — EV-013: RS-019 memuat marker.php dengan jumlah lampiran satu dan tautan Jalankan PHP.

Jumlah lampiran satu, nama `marker.php`, ukuran sekitar 0,1 KB, dan pilihan “Unduh file PHP” menunjukkan bahwa file telah tersimpan. Dokumen saat screenshot masih draft dan pemiliknya Alya. Bukti ini memenuhi tahap penerimaan/penyimpanan file; keberhasilan upload belum sendirinya membuktikan bahwa server akan mengeksekusinya.

Evidence VULN-03: output interpreter



Gambar 14 — EV-014: URL uploads berakhiran PHP menampilkan EXECUTED_5.

Address bar memperlihatkan file acak berakhiran `.php` di bawah `/uploads/`. Isi halaman berupa EXECUTED_5. Metadata database pada saat pencatatan menghubungkan nama simpan `37c64ddc2eea2f3ff6df28163342e2aa.php` dengan lampiran ID 25, nama asli `marker.php`, dan dokumen 19. Hasil manual konsisten dengan perilaku upload serta handler server yang ditemukan melalui source/config.

Gambar tidak membuktikan akses root, identitas user OS, shell interaktif, pembacaan file host, atau keluar container. Keberhasilan yang dapat dipastikan adalah eksekusi PHP dalam runtime aplikasi. Tes tambahan menunjukkan URL marker dapat dibaca oleh klien anonim setelah file diunggah; keterbukaan URL publik tersebut berasal dari run otomatis, bukan pengujian logout yang terlihat pada EV-014.

Bentuk request relevan VULN-03

Contoh berikut adalah rekonstruksi minimal alur request. Batas multipart dan nilai sesi bukan data mentah yang diekspor dari browser manual.

```
POST /api/documents/19/attachments HTTP/1.1
Host: 127.0.0.1:8080
Cookie: RUANGSURAT_VULNERABLE=[REDACTED]
X-CSRF-Token: [REDACTED]
Content-Type: multipart/form-data; boundary=VAPTBOUNDARY

--VAPTBOUNDARY
Content-Disposition: form-data; name="file"; filename="marker.php"
Content-Type: application/octet-stream

[source marker benign sebagaimana dicantumkan di atas]
--VAPTBOUNDARY--

GET /uploads/37c64ddc2eea2f3ff6df28163342e2aa.php HTTP/1.1
Host: 127.0.0.1:8080

Hasil browser manual: EXECUTED_5
```

Pola respons 201 pada upload dan 200 pada akses marker diverifikasi pada run API terpisah. Screenshot manual membuktikan tampilan output tanpa menampilkan status HTTP mentah.

Dampak terkonfirmasi dan potensial VULN-03

Dampak terkonfirmasi adalah file dari akun staf mencapai interpreter dan menjalankan ekspresi PHP. Kemampuan menempatkan kode arbitrer pada runtime berpotensi memengaruhi data serta storage yang dapat diakses proses aplikasi. Database dan lampiran berada pada volume writable yang dipakai aplikasi. Potensi tersebut menjelaskan prioritas teknis tinggi, tetapi pengujian tidak membaca seluruh database, merusak berkas, atau menghentikan layanan untuk membuktikan setiap konsekuensi secara destruktif.

Root filesystem read-only, eksekusi sebagai `www-data`, capability yang dibatasi, dan tidak diberikannya mount host arbitrer merupakan konteks pembatas. Kontrol tersebut tidak mencegah marker berjalan dan tidak mengubah file pengguna menjadi data aman. Pada saat yang sama, keberhasilan marker tidak cukup untuk menyatakan bahwa pembatasan container telah dilewati. Scope penilaian tetap aplikasi.

Justifikasi CVSS VULN-03

Metrik	Nilai	Alasan skenario
AV	N	Upload dan akses file berlangsung melalui HTTP
AC	L	Tidak memerlukan race condition atau konfigurasi tambahan dari penyerang
PR	L	Unggah memerlukan akun staf dan draft sendiri
UI	N	Pengunggah dapat membuka URL sendiri tanpa korban
S	U	Dampak dinilai dalam otoritas runtime aplikasi yang sama
C	H	Penilaian potensi kode arbitrer atas data yang dapat dibaca proses aplikasi
I	H	Penilaian potensi perubahan luas pada storage yang dapat ditulis proses aplikasi
A	H	Penilaian potensi gangguan besar pada aplikasi/data yang berada dalam otoritas proses

Vector menghasilkan 8.8, High. C:H/I:H/A:H menilai kemampuan kode dalam kewenangan proses aplikasi, termasuk akses storage. Bukti hanya berupa eksekusi marker; pencurian, penghapusan, dan DoS tidak dilakukan. Kemampuan kode membuat perbaikan upload menjadi P1. Tidak ada bukti keluar container atau akses host.

Rekomendasi perbaikan VULN-03

- Simpan file pengguna di luar web root atau pada layanan penyimpanan yang tidak mempunyai interpreter. Serve melalui endpoint terotorisasi yang mengirim data, bukan mengeksekusi file.
- Terapkan allowlist ekstensi yang dibutuhkan, batas ukuran, pemeriksaan MIME dari konten, serta verifikasi format gambar. Tolak tipe executable pada penggunaan normal.
- Jangan mempercayai MIME dari browser atau penggantian ekstensi. Pada fixed, file PHP bernama TXT dan gambar palsu juga harus ditolak sesuai fixture pengujian.
- Pertahankan nama acak untuk menghindari collision dan path yang dikendalikan pengguna, tetapi perlakukan ini sebagai kontrol tambahan, bukan larangan eksekusi.

- Nonaktifkan handler eksekusi di semua direktori upload yang dapat dijangkau web server. Pada fixed, akses publik ke direktori uploads ditolak dan file berada di private storage.
- Gunakan attachment disposition untuk unduhan. Jika diperlukan preview, izinkan hanya format yang diperiksa dan tipe MIME yang sesuai; endpoint preview tidak dijadikan jalur eksekusi PHP.
- Periksa data lama sebelum kandidat staging dipromosikan ke production. Penghapusan marker harus melalui inventaris artefak dan tidak menghapus evidence yang diperlukan untuk penilaian.
- Pemilik tindak lanjut fungsi: backend dan konfigurasi web server. Mitigasi harus diterapkan pada kandidat rilis dan diverifikasi kembali sebelum promosi ke production.

Kriteria retest VULN-03

Unggah PHP dengan sesi dan CSRF valid harus ditolak karena tipe/konten file, bukan kegagalan autentikasi. Uji juga PHP berekstensi TXT dan gambar palsu. File TXT normal dan PNG asli harus tetap dapat diunggah serta diunduh oleh pemilik/admin, dan PNG dapat dipreview. Preview bukan gambar harus ditolak. Akses direktori publik fixed harus diblokir. Hasil tambahan memenuhi variasi tersebut; pengujian ini tidak mencakup semua polyglot, parser, atau konfigurasi server lain.

5.3. Kontrol pembanding dan hasil negatif

Tes tambahan tidak hanya menguji payload sukses pada vulnerable, tetapi juga prasyarat akses dan fungsi sah. Hal ini membantu membedakan mitigasi yang bekerja dari request yang gagal karena sesi tidak valid. Pengujian memakai token CSRF target masing-masing profil dan dokumen milik akun yang benar.

Kontrol / skenario	Hasil pada tes tambahan	Batas kesimpulan
API privat tanpa login	401	Terbatas endpoint yang dipanggil
Direktori admin dengan sesi staf	403	Tidak menjadi finding akses fungsi admin
Edit/submit/upload dokumen staf lain	Ditolak	IDOR yang dilaporkan terbatas pada baca detail
Unduh lampiran milik staf lain	Ditolak	Tidak mengubah URL publik PHP vulnerable menjadi endpoint privat
POST tanpa token CSRF	403	Tidak menyatakan seluruh kemungkinan bypass CSRF telah diuji
Pemilik dokumen	Ditentukan dari sesi	Field owner_id dari client tidak mengambil alih kepemilikan pada test case
Edit setelah submit	Ditolak	Transisi state diperiksa pada alur uji
Persetujuan / penolakan admin	Berjalan sesuai status	Tidak membuktikan ketahanan seluruh alur bisnis
Logout lalu API privat	401	Skenario sesi yang diuji berakhir
PNG: preview, buka ukuran penuh, unduh	Berjalan pada kedua profil	Format yang diuji adalah PNG fixture asli
Preview tanpa hak / bukan gambar	Ditolak	Pemeriksaan otorisasi dan tipe pada endpoint preview
PHP pada vulnerable	Output EXECUTED_5	Eksekusi PHP; tidak ada perintah OS

5.4. Observasi di luar jumlah finding

OBS-01 — Framing pada vulnerable

Origin PoC dapat memuat vulnerable di iframe, sedangkan fixed diblokir oleh kebijakan framing. Ini menunjukkan perbedaan kontrol pembingkaian. Tidak dilakukan rangkaian overlay yang memicu persetujuan sensitif tanpa disadari pengguna, sehingga laporan tidak menambahkan finding clickjacking terpisah. Status observasi adalah informasi hardening; CVSS N/A karena dampak serangan terpisah belum dibuktikan.

OBS-02 — CORS pada informasi publik

Endpoint `/api/public/info` menyediakan informasi uji yang memang bersifat publik dan mengirim wildcard CORS. Tes browser dapat membaca data dari origin PoC tanpa kredensial. Tidak ada bukti bahwa endpoint tersebut membocorkan isi dokumen privat atau melanggar kebijakan akses. Wildcard tidak dinilai sebagai finding hanya berdasarkan keberadaan header. CVSS N/A; kontrol akses data privat tetap harus dinilai melalui skenario yang relevan.

5.5. Interpretasi gabungan

Ketiga finding menggambarkan batas kepercayaan yang berbeda dan tidak boleh digabung menjadi klaim serangan berantai yang belum diuji. IDOR tidak diperlukan agar staf membuat tautan atau mengunggah file pada draft sendiri. XSS admin tidak diperlukan untuk menjalankan marker PHP. Tidak ada bukti rantai yang menggunakan satu temuan untuk mendapatkan akses host melalui temuan lain. Pemisahan ini membuat akar masalah serta kriteria perbaikan masing-masing dapat diperiksa dengan jelas.

BAB 6 PENUTUP DAN RETEST

6.1. Kesimpulan

Assessment berhasil membuktikan tiga kelemahan pada RuangSurat vulnerable. Bukti VULN-01 menunjukkan Bima membaca dokumen Alya pada ID 12, sehingga batas kerahasiaan antarstaf gagal pada pembacaan detail. Bukti VULN-02 menunjukkan tautan JavaScript yang dibuat Alya disimpan pada ID 15 dan berjalan setelah dibuka Nadia, sehingga input staf menyeberang ke konteks browser administrator. Bukti VULN-03 menunjukkan `marker.php` pada ID 19 diproses server dan menghasilkan `EXECUTED_5`, sehingga batas antara data unggahan dan kode aplikasi gagal.

Distribusi severity teknis adalah satu High dan dua Medium. VULN-03 diprioritaskan karena kemampuan eksekusi kode dalam runtime aplikasi. IDOR dan Stored XSS juga membutuhkan perbaikan karena melanggar kebijakan kepemilikan dan kepercayaan terhadap konten. Tidak ada bukti akses root, container escape, takeover akun, eksfiltrasi, atau gangguan layanan; hal tersebut tidak dimasukkan sebagai hasil yang telah tercapai.

Kandidat perbaikan menunjukkan kontrol yang menolak skenario eksploitasi dan mempertahankan fungsi normal. Kesimpulan berlaku pada build dan variasi yang diuji. Baseline staging masih memerlukan penerapan mitigasi, sehingga status Open dipertahankan untuk kondisi tersebut. Persetujuan production hanya dapat mengacu pada kandidat yang telah diverifikasi, kelengkapan pemeriksaan operasional, dan keputusan pemilik aplikasi.

6.2. Rencana tindak lanjut

Prioritas	Tindakan	Penanggung jawab fungsi	Kriteria selesai
P1	Private storage dan pencegahan handler executable	Backend / pengelola web server	PHP ditolak/tidak dieksekusi; file sah tetap dapat diakses sesuai hak
P2	Otorisasi objek konsisten untuk halaman/API	Backend	Pemilik/admin diizinkan; staf lain/anonim ditolak tanpa isi
P3	Validasi URL dan sanitasi perilaku render legacy	Backend / frontend	Skema aktif ditolak; data lama tidak menjadi tautan berbahaya
Pendukung	Regresi API/browser dan inventaris build	Pengembang / tim penguji keamanan	Hasil disimpan dengan waktu, target, dan identifier build
Pendukung	Review keamanan dan perluasan coverage	Penyusun / reviewer yang ditunjuk	Catatan peninjauan dan penambahan uji sesuai kebutuhan

Seluruh temuan perlu ditangani sebelum promosi baseline ke production. Urutan P1–P3 menjadi dasar koordinasi tim aplikasi dan infrastruktur; tanggal implementasi serta risk acceptance ditetapkan pemilik aplikasi. Keberhasilan uji pada kandidat perbaikan harus diikuti penyamaan konfigurasi deployment dan pemeriksaan ulang terhadap artefak executable yang tersisa.

6.3. Pengelolaan dan pembersihan artefak

Artefak manual yang ditelusuri adalah RS-012, RS-015, RS-019, tautan `PENTEST_02`, serta lampiran `marker.php` dengan nama simpan acak dan ID lampiran 25. Tes tambahan membuat dokumen uji dan marker

tersendiri. Pada saat penyusunan tidak dilakukan reset atau penghapusan massal, agar objek serta bukti pengujian manual tetap dapat ditinjau.

Bukti pengujian disertakan langsung pada uraian tiap temuan dan bagian retest. Pembersihan database, sesi, dokumen uji, tautan marker, serta berkas executable perlu dijadwalkan oleh pengelola staging setelah verifikasi selesai. Laporan tidak menyatakan pembersihan telah dijalankan. Evidence dan laporan disimpan terpisah dari volume aplikasi untuk mempertahankan rekam audit.

6.4. Pelaksanaan retest pembanding

Retest tambahan dilaksanakan pada 22 Oktober 2026. Tes API berlangsung pukul **05:07:22–05:07:24 WIB**, sedangkan tes browser berlangsung pukul **05:07:24–05:07:32 WIB**, sesuai timestamp ISO pada `retest-run.json`. Exit code kedua proses adalah 0. Source browser yang sama dipakai dengan pengalihan folder output ke direktori pendukung laporan; log mencatat perintah aktual tersebut. Tujuannya mempertahankan snapshot validasi lama dan memisahkan hasil run baru dari bukti manual.

Finding	Request / kondisi eksploitasi pada fixed	Fungsi sah yang diperiksa	Status pada scope retest
VULN-01	Staf A membaca dokumen Bima melalui browser dan API: 404 tanpa isi	Pemilik dan admin tetap membaca; dashboard sesuai pemilik	Fixed pada test case yang dijalankan
VULN-02	Penyimpanan JavaScript: 422; fixture legacy tidak menjadi anchor aktif	HTTP/HTTPS sah diterima; admin meninjau dan memutuskan pengajuan	Fixed pada test case yang dijalankan
VULN-03	PHP: 422; PHP dalam TXT dan gambar palsu ditolak; lokasi publik fixed diblokir	TXT/PNG normal, download, dan preview PNG berjalan	Fixed pada variasi yang dijalankan

Run API terdiri dari dua metode tes, `test_both_profiles` dan `test_image_preview`, yang masing-masing menjalankan banyak assertion pada dua profil. “Ran 2 tests” bukan berarti hanya dua request dikirim. Run browser memeriksa interaksi nyata, termasuk dialog XSS vulnerable, output PHP, popup gambar, unduhan, role admin, dan kontrol pembanding fixed.

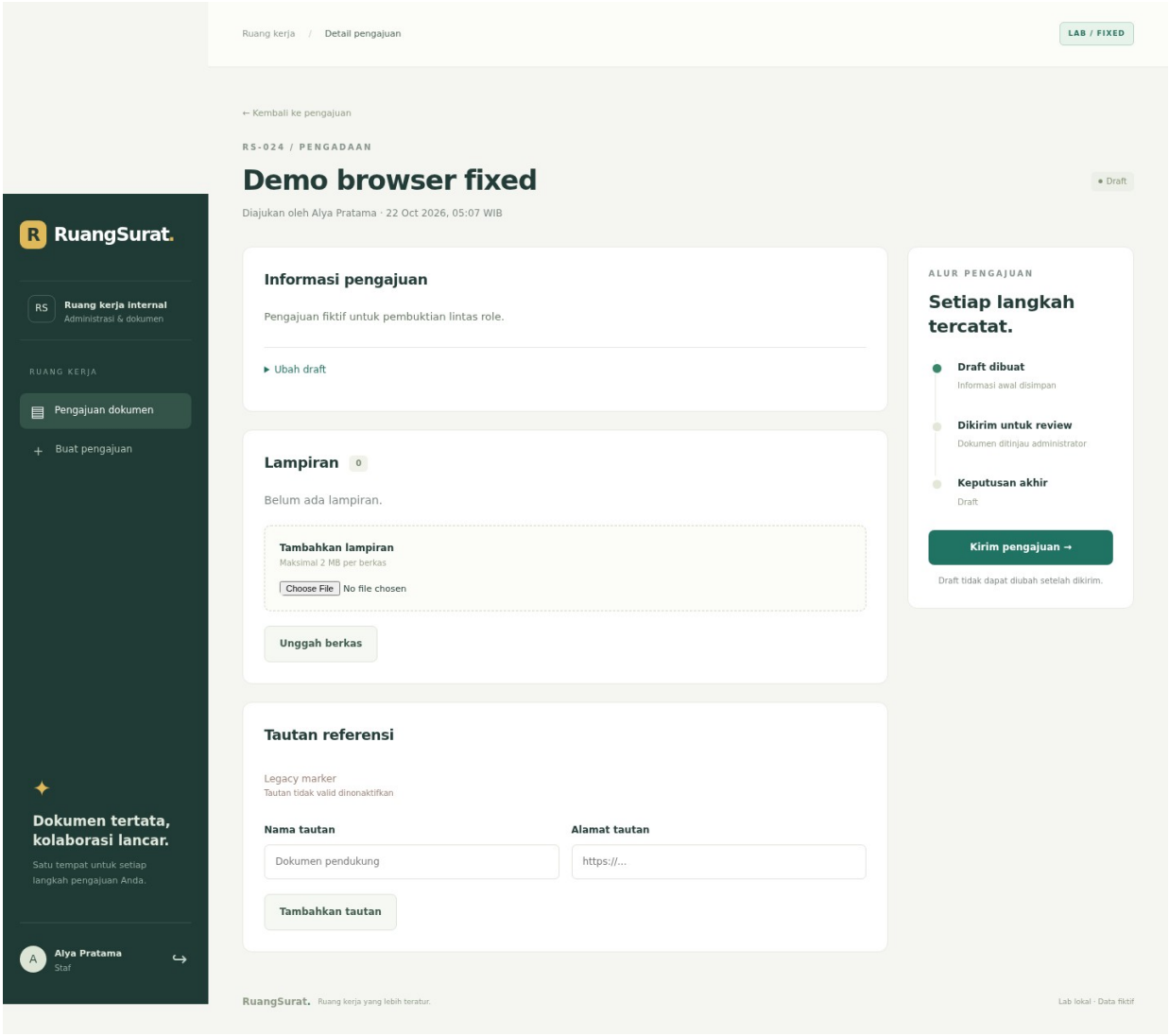
Bukti tambahan: penolakan IDOR fixed



Gambar 15 — EV-SUP-03: akses silang pada fixed tidak mengembalikan dokumen.

Screenshot berasal dari tes otomatis dengan sesi staf dan objek awal pengujian fixed, bukan dari RS-012 manual. Respons browser berstatus 404 dan menampilkan dokumen tidak ditemukan. Assertion terpisah memastikan pemilik/admin tetap dapat mengakses objek yang diizinkan, sehingga hasil ini tidak disimpulkan hanya dari request dengan sesi yang salah.

Bukti tambahan: penonaktifan tautan legacy fixed



Gambar 16 — EV-SUP-04: tautan JavaScript lama pada fixed ditampilkan sebagai teks nonaktif.

Fixture data legacy dimasukkan melalui akses operator pada database dokumen uji yang dibuat tes, lalu halaman dirender kembali. Tampilan menunjukkan tautan tidak valid dinonaktifkan; assertion browser memastikan tidak ada anchor dengan `href` JavaScript. Ini menguji rendering data lama dan bukan bukti bahwa request upload/tautan biasa dapat melewati validasi fixed.

6.5. Residual risk dan batas retest

Tidak ada variasi yang menunjukkan bypass baru pada rangkaian tes yang dijalankan. Namun, retest tidak mencakup semua file polyglot, semua parser PDF/gambar, seluruh workflow bisnis, semua konfigurasi deployment, atau semua cara interaksi browser. Profile vulnerable masih memiliki kelemahan yang terkonfirmasi. Pada lingkungan lain, data lama, mount tambahan, perubahan handler, dan sensitivitas dokumen dapat mengubah dampak serta kebutuhan mitigasi.

Status temuan ditetapkan per build: VULN-01, VULN-02, dan VULN-03 adalah Open pada baseline staging dan Fixed pada skenario kandidat perbaikan yang diuji. Production tidak termasuk target assessment. Hasil retest merupakan bukti teknis pendukung evaluasi go-live, sedangkan keputusan promosi dan penerimaan risiko berada pada pemilik aplikasi.

REFERENSI SINGKAT

- PTES — kerangka pelaksanaan dan pelaporan pengujian
- OWASP WSTG v4.2 — panduan skenario pengujian aplikasi web
- OWASP Top 10:2025 — kategori risiko keamanan aplikasi web
- FIRST CVSS v3.1 — dasar penilaian severity teknis
- CWE — klasifikasi kelemahan: CWE-639, CWE-79, dan CWE-434